HEART: Hybrid Evidence-based AI Risk Taxonomy for General, Agentic, and Physical AI

Frontier AI Lab, KT Corporation
responsible.ai@kt.com

Abstract

AI is becoming more capable, adaptive, and embedded in everyday life. AI systems increasingly combine general-purpose models, memory-equipped agents, and physical actuation, so that risks can interact across interpretation, delegated decision-making, and physical contact with people. This integration raises two complementary problems. The mechanistic problem is that domain-specific classifications can identify individual risks without making their interconnections explicit. The methodological problem is that a taxonomy must incorporate emerging evidence while keeping its categories consistent: fixed frameworks may overlook new mechanisms, whereas unconstrained, evidence-driven grouping may yield overlapping categories and uneven granularity. This report presents HEART, a Hybrid Evidence-based AI Risk Taxonomy, which addresses the methodological problem through hybrid construction and the mechanistic problem through service-specific application profiling. Top-down concepts drawn from prior research, governance frameworks, and safety standards are reconciled with bottom-up evidence through expert review. The resulting hierarchy organizes 622 bilingual, evidence-linked risk cards into 47 risk categories across General AI (general-purpose AI models), Agentic AI, and Physical AI; each card retains a stable primary classification while remaining open to controlled revision. Application profiles select relevant categories across inherited domains and associate them with service stages and control requirements. A hypothetical urban delivery-robot service illustrates this approach across order intake, route planning, sidewalk navigation, recipient handoff, remote assistance, and maintenance. The profile supports assessment coverage and the further investigation of risk interactions; it does not establish causal relationships, incident probabilities, or control effectiveness. HEART thus contributes a traceable method for construction and revision, together with a common vocabulary for examining interactions among risks, that supports targeted assessment and control assignment while keeping new evidence and changing service conditions open to review.

Keywords AI risk taxonomy; hybrid taxonomy; evidence-based taxonomy; General AI; Agentic AI; Physical AI; risk cards; human-in-the-loop governance.

1 Introduction

1.1 Why an AI Risk Taxonomy Is Needed Now

AI is becoming more capable and adaptive. General-purpose models increasingly support systems that remember prior interactions, plan through tools, coordinate with other agents, and operate in shared physical environments. Established concerns such as misinformation, privacy loss, discrimination, and security failure remain relevant, but their consequences depend increasingly on how interpretation, delegated authority, and execution are connected. A misunderstood instruction can become an agent's action plan and then a hazardous robot handover; effective clarification, permission checks, or independent safety controls can interrupt that pathway. Identifying each constituent risk is therefore necessary but not sufficient for assessing an integrated service.

The first problem is mechanistic. Domain-specific categories can identify model, agent, or robot failures without explicitly representing how those mechanisms interact. The difficulty is not that existing frameworks are isolated silos; sociotechnical and embodied-AI research already examines broader harms and pipeline-level failures [1–3]. Rather, a hierarchy that assigns each risk to a single domain does not, by itself, specify the conditions that connect separate failures. Embodied AI illustrates this gap: despite such pipeline-level analyses,

safety research on long-horizon robotic systems remains fragmented across planning, control policy, and execution, even though semantic misgrounding, subtask errors, and execution drift can accumulate within the same system [4]. This accumulation mirrors the interpretation–delegation–execution chain described above. An adequate taxonomy must therefore distinguish inherited model risks from agency- and embodiment-specific mechanisms while permitting service-specific analysis of their interactions.

The second problem is methodological. An upper structure fixed entirely in advance may represent unfamiliar evidence poorly, whereas an inventory derived without conceptual constraints may reproduce corpus biases, duplicate mechanisms, and exhibit uneven granularity. Iterative taxonomy-development research already combines conceptual and empirical development [5, 6]; the challenge here is to operationalize that balance for changing AI capabilities, bilingual risk formulations, and cross-domain boundary decisions. Extensibility therefore requires a reviewable way to revise risk cards (the atomic, evidence-linked units defined in Section 3) and categories without sacrificing comparability.

These problems call for complementary responses. HEART (Hybrid Evidence-based AI Risk Taxonomy) addresses the methodological problem through hybrid construction, in which experts reconcile top-down concepts with bottom-up evidence to build and maintain consistent categories. It addresses the mechanistic problem through application profiles, which select relevant categories across domains and associate them with service stages, affected parties, and controls; these profiles provide a basis for investigating interactions with service-specific evidence. Neither process establishes real-world causation or safety.

1.2 Terminology: General AI, Agentic AI, and Physical AI

HEART organizes AI risks under three operating domains. Because these labels are used inconsistently in the literature, this report defines them explicitly before use.

Operating-domain terms

General AI denotes general-purpose AI models that display significant generality, competently perform a wide range of distinct tasks, and can be integrated into diverse downstream systems [7, 8]; in this report, their primary inputs and outputs are digital content such as text, images, audio, video, and code. The label does *not* refer to artificial general intelligence (AGI).

Agentic AI denotes AI systems that pursue goals with limited human supervision by planning and taking consequential actions, typically through tool use, persistent memory or state, delegation, or interaction with other agents [9, 10]. They act on external systems directly rather than only producing content for a person to act on.

Physical AI denotes AI systems, such as robots, autonomous vehicles, and humanoids, that perceive, decide, and act in the physical world through a material perception–action loop in which sensing, world-state estimation, control, actuation, mechanical integrity, or physical human–system interaction is constitutive [2, 3].

The three domains are nested rather than disjoint in practice: an agent is usually built on a general-purpose model, and a robot may use both. HEART therefore assigns a risk to Agentic AI or Physical AI only when agency or embodiment is constitutive of its mechanism; otherwise, the risk is classified under General AI and inherited by agentic and physical services (Section 3.3). Hereafter, *General AI*, *Agentic AI*, and *Physical AI* refer to these three L1 operating domains, whereas the lowercase term "general-purpose model" refers to the underlying model technology.

1.3 Research Questions and Design Requirements

The study addresses two research questions (RQ1 and RQ2) corresponding to these problems. **RQ1 (mechanistic):** How can a common classification preserve distinct risk mechanisms while enabling analysis across General AI, Agentic AI, and Physical AI? **RQ2 (methodological):** How can emerging evidence be incorporated without uncontrolled duplication or unstable category boundaries? The practical motivation arises from comparative risk assessments of models, agents, and services at KT, in which similar harm labels can conceal

different intervention requirements. For example, disclosure of sensitive data by a model, transmission through an agent's tools, and persistent recording by a robot involve different permissions, sensing, and monitoring conditions.

These questions impose four design requirements, which Section 3.6 operationalizes as six design principles. First, risks must be specific enough to support evaluation and control assignment. Second, each card must have a stable primary path and traceable evidence. Third, computational suggestions must remain subject to semantic adjudication. Fourth, application-specific relationships must preserve category definitions. The NIST AI Risk Management Framework (AI RMF), ISO/IEC 23894, machinery risk-assessment principles, and the EU AI Act provide complementary governance and safety foundations for these requirements [7, 11–13].

1.4 Scope of the Report

HEART connects risk identification with assessment and mitigation, organizing risks into System, Interaction, and Societal Impact areas across General AI, Agentic AI, and Physical AI.

The analytical scope covers the AI lifecycle, including data, model behavior, evaluation, tools, delegated decisions, sensing, control, human interaction, and institutional deployment. A hypothetical urban delivery-robot service (Section 6) illustrates how inherited risks are profiled across six service stages, from order intake to maintenance; it is an illustrative application profile rather than a field study.

1.5 Contributions

The report makes four contributions, which address the research questions through taxonomy construction and application.

1. A hybrid construction and revision procedure reconciles prior concepts with heterogeneous evidence through explicit boundary review, consolidation, and expert adjudication (RQ2).
2. A five-level hierarchy contains 47 formal categories and 622 bilingual risk cards, preserving primary classifications and evidence links across the three operating domains (RQ2).
3. Service-specific mapping distinguishes stable classification from context-dependent applicability and control requirements, allowing common categories to be used across deployments (RQ1).
4. A worked urban delivery-robot profile illustrates how inherited model, agentic, and physical risks can inform assessment coverage across service stages (RQ1).

The claimed value lies in traceable organization and analytical reuse; effects on deployment safety and comparisons with alternative construction methods are left to future work (Section 7).

The remainder of the report is organized as follows. Section 2 reviews the methodological basis and identifies the mechanistic and methodological gaps. Section 3 defines the unit of analysis and the design rationale, and Section 4 describes the construction method. Section 5 reports the resulting hierarchy and evaluates the supporting algorithms. Section 6 applies the taxonomy to the delivery-robot service. Section 7 outlines limitations and future directions, and Section 8 concludes.

2 Prior Methodological Basis

2.1 Risk Repositories, Frameworks, and Taxonomy Development

Risk repositories and survey taxonomies provide broad coverage and a vocabulary for comparing harms. The MIT AI Risk Repository synthesizes multiple classification systems into a causal and domain-oriented resource, while language-model taxonomies organize risks associated with discrimination, misinformation, malicious use, human-computer interaction, and broader social effects [14, 15]. Their organizing choices also reveal that category boundaries depend on analytical purpose. A repository optimized for comparative retrieval does not necessarily provide the atomic, versioned units required for system-level assessment.

Taxonomy-development research provides a complementary methodological basis. Iterative conceptual-to-empirical and empirical-to-conceptual development has been formalized around a defined meta-characteristic and explicit ending conditions [5]. Subsequent guidance emphasizes transparent construction decisions and explicit evaluation [6]. Accordingly, the present study derives upper-level concepts from prior frameworks, examines evidence inductively, and subjects the computational proposals to documented expert review rather than relying on clustering alone. Table 1 summarizes the principal organizing structures of the prior taxonomies, governance frameworks, and standards discussed in this section.

Table 1. Prior risk taxonomies, governance frameworks, and standards, with their principal organizing structures.

Work	Primary orientation	Principal organizing structure
Weidinger et al. [15]	Language-model harm	Discrimination, hate speech, and exclusion; information hazards; misinformation harms; malicious uses; human–computer interaction harms; environmental and socioeconomic harms
MIT AI Risk Repository [14]	Meta-review and repository	Causal taxonomy by entity, intent, and timing; domain taxonomy spanning discrimination and toxicity, privacy and security, misinformation, malicious actors and misuse, human–computer interaction, socioeconomic and environmental harms, and AI system safety, failures, and limitations
NIST AI RMF [11]	Lifecycle governance	Govern, Map, Measure, and Manage functions
NIST Generative AI Profile [8]	General-purpose generative AI	Cross-sectoral risks and actions organized as a profile of the AI RMF functions
OECD classification framework [16]	Policy-oriented system characterization	People and planet; economic context; data and input; AI model; task and output
OWASP Top 10 for LLM Applications [17]	Application security	LLM application vulnerabilities, including prompt injection, sensitive-information disclosure, excessive agency, supply-chain risk, and unbounded consumption
MITRE ATLAS [18]	Adversarial threat knowledge	Tactics, techniques, procedures, mitigations, and case studies for attacks on AI-enabled systems
ISO 12100 [13]	Machinery safety	Hazard identification, risk estimation, risk reduction, and protective measures

Governance and safety standards inform impact assessment, risk management, and functional-safety considerations [12, 19, 20]. Incident resources distinguish observed events and near misses from prospective hazards, while remaining subject to incomplete reporting [21]. The attack-focused resources in Table 1 inform security review, although accidental failures and deliberate attacks remain analytically distinct.

2.2 General AI and Sociotechnical Harm

General-purpose and generative models require categories that travel across applications without losing deployment context. The NIST Generative AI Profile connects model-level concerns to lifecycle risk-management actions, while the OECD classification framework characterizes systems through people and planet, economic context, data and input, model, and task and output dimensions [8, 16]. Sociotechnical harm research further distinguishes representational, allocative, quality-of-service, interpersonal, and societal harms, showing that model behavior and institutional use cannot be assessed in isolation [1]. These works support a broad General AI domain, but they do not by themselves supply the stable, evidence-linked risk cards and inheritance rules needed when the same model becomes part of an agent or embodied system.

2.3 Agentic AI Governance and Evaluation

Agentic systems change the unit of analysis from an isolated output to a sequence of stateful decisions and actions. Governance research identifies harms associated with delegated goals, authority, persistence, monitor-

ing, and accountability [9, 10]. Evaluation studies expose complementary operational failure modes. AgentBench tests reasoning and decision-making across interactive environments, while AgentDojo evaluates utility and prompt-injection security when agents act through tools over untrusted data [22, 23]. These resources justify dedicated Agentic AI categories for goal pursuit, excessive authority, traceability, coordination, and cascading behavior while preserving inherited General AI risks.

2.4 Embodied and Cross-Domain Risk Taxonomies

Policy-derived and embodied-AI taxonomies clarify why an upper hierarchy cannot be designed from text-safety categories alone. AIR 2024 derived 314 categories from government and corporate policies and organized them under System and Operational, Content Safety, Societal, and Legal and Rights risks [24]. This separation supports an upper structure that distinguishes where a failure is generated and governed from the type of harm eventually observed.

Recent embodied-AI research adds complementary technical and policy views. Li et al. trace safety issues across perception, cognition, planning, action, interaction, and agentic coordination, including endogenous failures and adversarial vulnerabilities that can propagate through an embodied pipeline [2]. Perlo et al. organize embodied-AI risks into physical, informational, economic, and social dimensions and identify policy gaps that extend beyond conventional robot-safety rules [3]. Safe-BeAl shows that non-adversarial task planning can create physical hazards across multiple hazard classes, making hazard-oriented benchmarks useful evidence for Physical AI even though they do not constitute a complete governance taxonomy [25]. Together, these studies motivate a hierarchy that combines operating domain, governable risk location, stable risk family, and evidence-level risk cards rather than adopting any single pipeline, attack, hazard, or impact axis as the whole taxonomy.

Long-horizon manipulation research links semantic misgrounding, subtask error propagation, and contact-rich execution [4]. This perspective motivates examining connected interpretation, planning, and execution mechanisms rather than isolated robot actions, and the delivery-robot example in Section 6 uses it to select categories across these stages.

Human–robot interaction research also distinguishes task failures from their effects on human trust and perceptions of the robot [26, 27]. These studies inform the human-facing risk mechanisms represented in the taxonomy.

2.5 Mechanistic and Methodological Gaps

The mechanistic gap lies between classifying constituent risks and examining their interactions within a service. Existing repositories, agent evaluations, embodied pipelines, and human–robot interaction studies offer complementary views. Their categories and findings do not automatically specify how an interpretation error, permission decision, human intervention, and physical action become connected in a particular deployment. Combining domain labels in one hierarchy does not close that gap; explicit application-level mapping is also required. HEART addresses this gap through the application profiling described in Sections 3.5 and 6.

The methodological gap concerns maintaining classification as evidence changes. Top-down concepts support interpretability but can constrain recognition of unfamiliar mechanisms. Unconstrained bottom-up grouping can generate overlap, uneven specificity, and categories reflecting the available corpus rather than the intended analytical purpose. Iterative conceptual–empirical methods already address these tensions in principle [5, 6], so the remaining gap is one of operationalization. General method guidance does not by itself specify how that logic should be applied to evidence-linked, bilingual cards whose boundaries cross operating domains. HEART applies it through reviewed inheritance rules and documented merges, splits, reassignments, and wording changes.

2.6 Hybrid Construction and Context-Specific Application

HEART addresses the methodological gap through expert-led best-fit framework synthesis, in which an a priori framework is used to code evidence and is revised where the evidence does not fit it [28]. Its top-down

direction establishes the accountability root, operating domains, risk areas, definitions, and inclusion criteria from prior research, governance frameworks, and standards. Its bottom-up direction identifies candidate risks from scientific publications, policy and technical reports, and patents. Iterative expert adjudication connects these two directions (Figure 1). Evidence that no existing category fits can motivate revision, but only through explicit expert adjudication; conversely, existing definitions constrain assignment without suppressing a distinct mechanism supported by evidence. "Evidence-based" therefore refers to traceable evidentiary grounding and reviewable lineage, not to automatic induction from corpus frequency. The methodological contribution lies in combining cross-domain inheritance, evidence-linked risk cards, stable identifiers, and documented revision, rather than in hybrid development itself, which is established in prior work. The resulting cards supply a consistent vocabulary for application profiles, where proposed interactions and intervention points are recorded separately from hierarchy membership. Application profiling, the second component, addresses the mechanistic gap without converting semantic proximity into a causal relation.

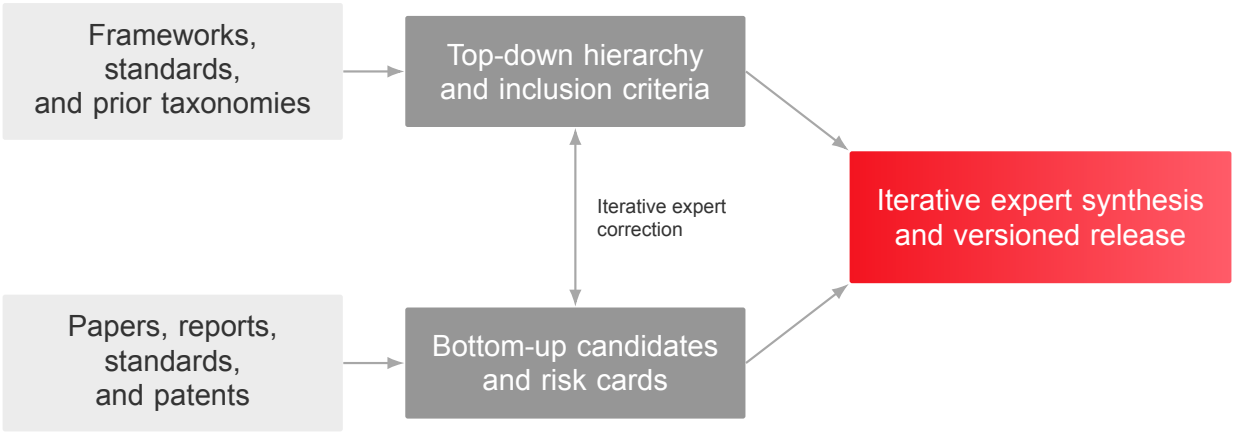


Figure 1. Hybrid response to the methodological gap. Top-down architecture and bottom-up evidence are joined through expert best-fit synthesis, not through automatic category creation.

3 Scope and Design Rationale

3.1 Scope and Unit of Analysis

Core concepts

Harm is an adverse effect on a person, group, organization, society, environment, asset, or protected interest. A **hazard** is a source or condition with the potential to cause harm. **Risk** is the possibility, with uncertain likelihood and consequence, that an AI-related mechanism, event, or condition produces harm in a stated context. An **incident** is an observed event, or series of events, that causes harm or operational disruption; a **near miss** could plausibly have caused harm but did not. These distinctions follow risk-management and incident-reporting practice [11, 12, 21].

An **AI risk card** is the smallest evidence-linked unit of classification and review. It is a stable, bilingual formulation that identifies the causal mechanism or failure mode, the affected object or protected interest, and the plausible adverse consequence, and it records its primary hierarchy path and supporting evidence. Unlike a keyword, incident narrative, broad outcome, or mitigation, a card is specific enough to support evaluation and control assignment yet general enough to recur across comparable deployments.

HEART treats the risk card, rather than the source document or observed incident, as its unit of taxonomy construction. The scope includes risks originating in model behavior, data and infrastructure, human interaction, delegated action, multi-agent coordination, sensing, control, physical interaction, and institutional deployment. Hazards in which AI plays no material role are excluded. Downstream impacts remain eligi-

ble when AI materially contributes to the harm, but speculative downstream effects do not override a card's defining mechanism and approved category boundaries.

3.2 Five-Level Taxonomy Architecture

Table 2. Five-level architecture of the HEART taxonomy.

Level	Governance role	Definition
L0	Accountability root	Responsible AI (`L0_RAI`) as the common root for organizing risks in support of responsible AI governance and accountability.
L1	Operating domain	General AI, Agentic AI, or Physical AI, identified through the risk mechanism and approved category boundaries.
L2	Risk area	System, Interaction, or Societal Impact, identifying where the risk is primarily managed.
L3	Risk category	A stable risk family used for evaluation design, ownership, aggregation, and reporting.
L4	Risk card	The atomic bilingual, evidence-linked risk formulation used in operational reviews.

Table 2 defines the governance role of each level, and Figure 2 summarizes the HEART construction logic. The upper hierarchy is initially established top-down from prior taxonomies, governance frameworks, and standards, then refined through expert review, while evidence is synthesized bottom-up into risk cards. Iterative expert reconciliation pursues near-MECE boundaries (Section 3.4), resolves duplicate or cross-domain candidates, and permits an upper-level revision only through explicit expert review.

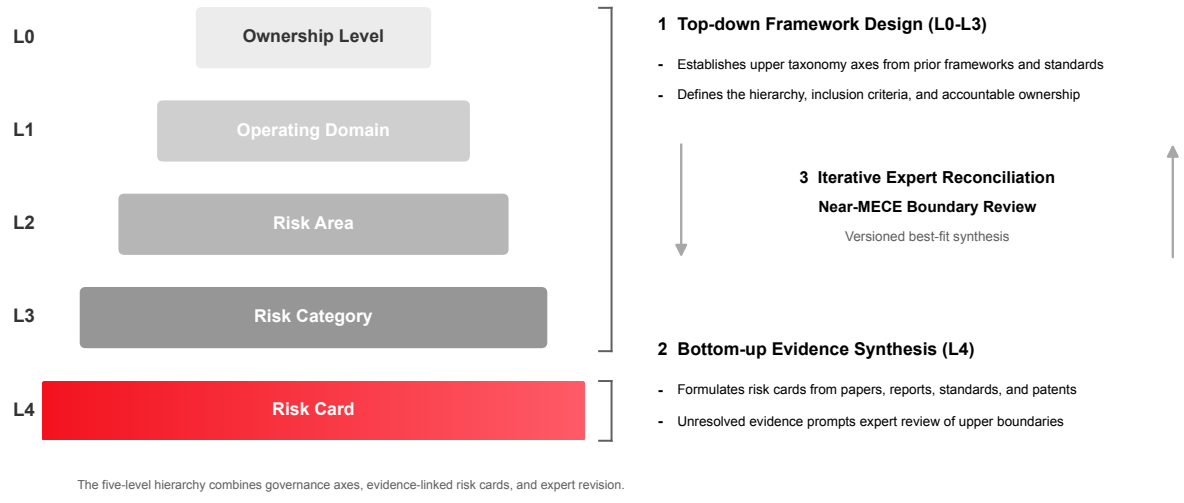


Figure 2. Design principles for the five-level taxonomy. Top-down framework design defines L0–L3; bottom-up evidence synthesis constructs and maps L4 risk cards; iterative expert reconciliation maintains near-MECE boundaries and controlled hierarchy revision.

3.3 Operating Domains and Cross-Domain Inheritance

Section 1.2 defines the three operating domains; for classification, their boundaries are operationalized as follows. **General AI** covers model-level and associated interaction or societal-impact mechanisms that do not require delegated agency or physical embodiment. **Agentic AI** adds autonomous goal pursuit, consequential action, tool use, persistent state, delegation, or multi-agent interaction; the conceptual treatment is consistent

with recent agent-governance work [9, 10]. **Physical AI** requires a material perception–action loop in which sensing, world-state estimation, control, actuation, mechanical integrity, or physical human–system interaction is constitutive [2].

Inheritance is explicit. An agent built on a general-purpose model can inherit misinformation, privacy, and adversarial-security risks. A robot with an agentic planner can inherit those risks and add excessive authority, coordination, sensor-fusion, control, and human–robot safety risks. The application profile in Section 6 uses this inheritance model while preserving each selected category's identifier.

Because inheritance makes the same category applicable to many services, application profiling separates stable taxonomy categories from context-dependent applicability, affected parties, severity, and control requirements. This distinction is consistent with policy-oriented classification approaches that characterize an AI system through its social and economic context, data and inputs, model properties, and task and output [16].

3.4 Near-MECE Design Objective

A strictly MECE (mutually exclusive and collectively exhaustive) structure is unattainable in practice because an AI failure can traverse several mechanisms. A compromised perception model may produce a false world state, unsafe planning, and physical collision. The taxonomy therefore treats near-MECE structure as an explicit approximation. Each card has one primary category based on its defining mechanism, its supported direct consequence, and the approved category boundaries. For observed incidents, placement considers the direct harm actually documented rather than speculative downstream effects. Prospective cards identify plausible risks without claiming that harm has occurred. A single primary path prevents double counting, but classification alone does not resolve legal, moral, or institutional accountability.

Primary assignment applies the inclusion and exclusion criteria of the relevant L3 category. The definitions in Appendix A distinguish neighboring categories. For example, failure of the robot's own motion control belongs to Unsafe Physical Control and Actuation, whereas failure to accommodate people despite normally functioning control belongs to Human-Robot Physical Safety Failure. A merely possible later collision does not determine the classification of an earlier failure.

3.5 Classification and Failure-Mode Mapping

A *failure mode* describes how a function, interaction, or control can fail within a stated service. A taxonomy category may represent that mechanism across many applications; a service pathway links several mechanisms under explicit conditions. Not every risk is a functional failure. Harmful outcomes may also arise from intended behavior, institutional choices, or misuse. The urban delivery-robot profile in Section 6 selects categories relevant to service stages; further failure-mode analysis would require evidence about the conditions connecting them.

A proposed pathway should identify a triggering condition, the relevant category IDs, the condition permitting continuation, the plausible consequence, and possible intervention points. Links indicate analytical hypotheses and must be supported or revised with service-specific evidence; neither shared domain membership nor embedding similarity establishes a causal edge. Several categories may describe one scenario without duplicating a card's primary path. Recording pathways separately from the hierarchy distinguishes stable classification, which serves RQ2, from the analysis of combined behavior, which serves RQ1.

3.6 Design and Update Principles

The six design principles of HEART are definitional consistency, source traceability, atomicity, duplicate control, stable identifiers, and expert approval. These principles operationalize the four design requirements in Section 1.3: atomicity and duplicate control make risks specific enough for evaluation and control assignment; source traceability and stable identifiers secure a stable primary path with traceable evidence; expert approval keeps computational suggestions subject to semantic adjudication; and definitional consistency ensures that application profiles reuse, rather than redefine, category definitions. Computational methods propose candidates and detect inconsistencies; they do not create or rewrite categories without review. Revisions must preserve

the correspondence between evidence, definitions, and primary classifications. The taxonomy remains open to new mechanisms and revised boundaries; it does not claim exhaustive coverage. It is an instrument for risk identification and accountability within responsible AI governance, not a comprehensive definition or certification of responsible AI.

4 Methodology

4.1 Construction Procedure

HEART was constructed through deductive, inductive, and adjudicative stages. Deductive design established provisional upper-level concepts and inclusion criteria; inductive synthesis retrieved and consolidated candidate mechanisms from heterogeneous evidence; adjudication assessed fit, duplication, and boundary implications. The resulting bilingual taxonomy assigns each card one primary hierarchy path and records its derivation. The statistical unit changes across stages. Source documents provide evidence, candidate statements express proposed formulations, and cards constitute the smallest classified units. Counts across these stages therefore do not represent a one-to-one conversion rate or an estimate of risk prevalence.

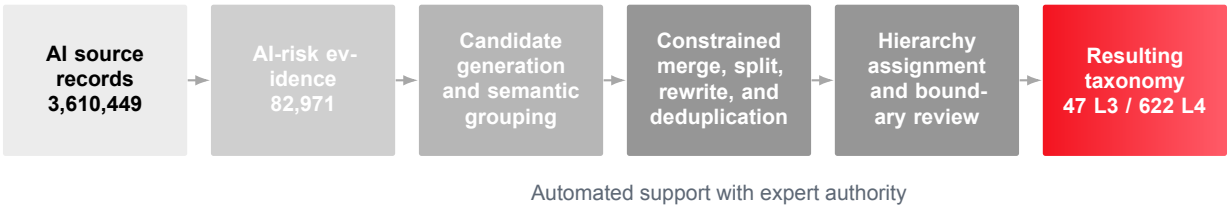


Figure 3. Taxonomy construction procedure. Evidence records were synthesized and adjudicated into risk cards; the stages use distinct statistical units.

Top-down design supplies the hierarchy and inclusion criteria; the remaining stages construct and screen the corpus, generate and consolidate candidates, and propose hierarchy assignments for expert review (Figure 3). Automated grouping and assignment support review without authorizing category changes. Structural verification is reported in Section 5.

Prior concepts constrain abstraction and inclusion, while evidence can reveal missing distinctions. Expert adjudication reconciles the two. This complementarity motivates the hybrid design.

4.2 Evidence Space and Corpus Construction

4.2.1 Evidence Sources

The evidence space combines scientific publications, policy and technical reports, and patents. Scientific literature contributes observed failures, evaluation results, and emerging mechanisms. Policy and technical reports contribute institutional concerns and governance requirements. Patents indicate intended capabilities and deployment mechanisms before incidents are widely reported.

Each record retains, when available, a source identifier, title, abstract or executive summary, publication year, authors or issuing organization, DOI or URL, source family, retrieval date, and processing provenance. Independent sources are not collapsed merely because they describe the same risk, because source diversity is itself informative. Exact duplicates within a source type are removed using persistent identifiers first and normalized title keys second.

4.2.2 Corpus Integration and Screening

The construction baseline contains 3,610,449 normalized AI source records from the 1950s through July 2026. Risk-focused source rules, lexical markers, semantic retrieval, and human review retained 82,971 AI-risk evidence records. The retained evidence describes an AI failure, hazard, misuse, vulnerability, unsafe interaction, governance gap, or adverse social effect. Table 3 summarizes this funnel and the statistical unit at each stage.

Table 3. Evidence-to-taxonomy construction baseline.

Stage	Count	Statistical unit
AI source space	3,610,449	Normalized records from heterogeneous AI sources
AI-risk evidence	82,971	Records retained by reviewed source, semantic, and lexical screening
Current taxonomy	622	Bilingual L4 risk cards after consolidation and expert review

The 82,971 records include 50,375 scholarly publications, 938 policy and report records, and 31,658 patents. Resolved author affiliations of the scholarly and policy/report records span 164 countries, led by China and the United States.

4.2.3 Tri-Domain Filtering

The semantic-retrieval component of this screening relies on domain-specific anchors. For each document d_i, the retrieval text is formed by concatenation,

$$x_i = \text{title}(d_i) \| \text{abstract}(d_i) \| \text{keywords}(d_i). \tag{1}$$

where $\|$ denotes string concatenation. Reviewed definitions and examples form anchor sets $\mathcal{A}_G$, $\mathcal{A}_A$, and $\mathcal{A}_P$ for General AI, Agentic AI, and Physical AI. A record may be retained when it belongs to a reviewed risk source, is semantically close to a domain or risk anchor, or contains explicit risk, safety, failure, security, misuse, ethics, or governance markers that survive review. Cross-domain candidates remain eligible for review against their stated mechanism, supporting evidence, and the approved category boundaries. Prospective risk cards do not require an observed incident.

To illustrate the outcome of this filtering for the narrowest domain, Figure 4 locates Physical AI risk evidence within the broader AI document space.

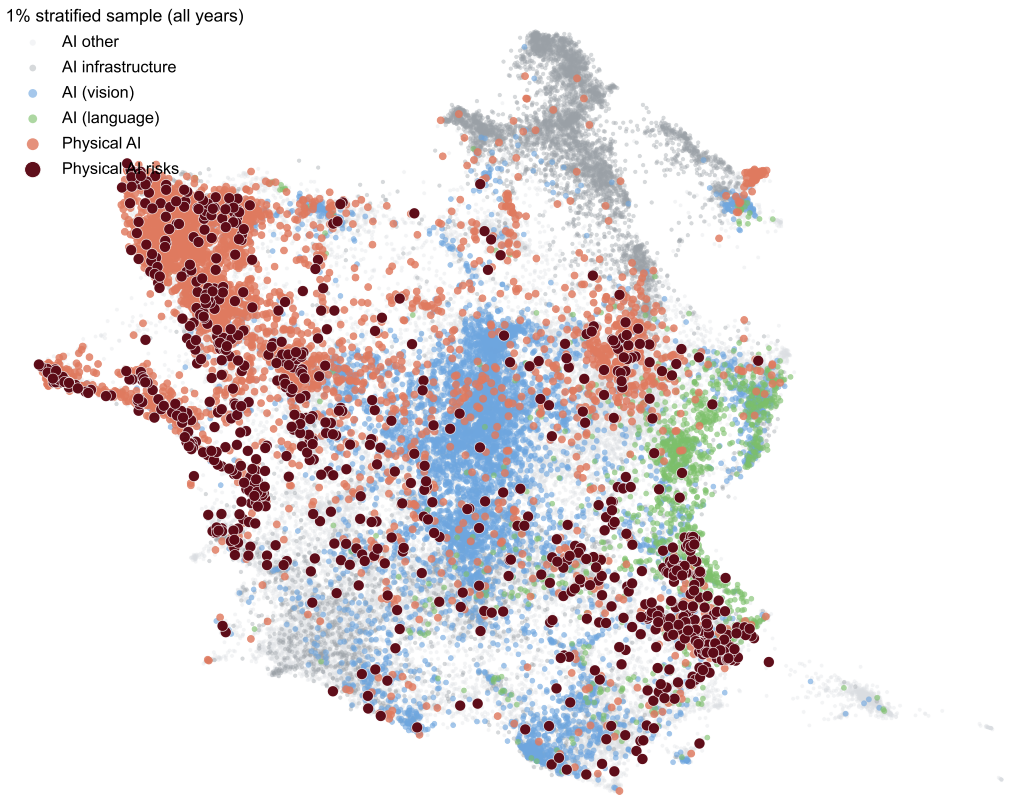


Figure 4. Physical AI document-space diagnostic based on a 1% stratified sample of the integrated AI corpus. Each point is one document, positioned by a two-dimensional projection of its text embedding so that semantically similar documents lie close together; the axes carry no substantive units and are omitted. Colors indicate document groups: AI other (light gray), AI infrastructure (gray), AI vision (blue), AI language (green), and Physical AI (orange). Physical AI risk evidence retained by screening is overlaid as larger dark-red points. The overlay concentrates within and along the edges of the Physical AI regions but also extends into neighboring regions, which is why cross-domain candidates require review against supporting evidence and approved category boundaries.

4.3 Risk Candidate Generation and Consolidation

4.3.1 Semantic Representation and Clustering

Candidate formulations are extracted or drafted from the retained evidence records so that each states the AI role, mechanism, affected object, and plausible adverse consequence (Algorithm 1, step 3); as noted in Section 4, records and candidates are not in one-to-one correspondence. Candidate text combines a provisional name, definition, evidence sentence, and normalized keywords. The BGE-M3 embedding model provides multilingual dense representations, HDBSCAN (hierarchical density-based spatial clustering of applications with noise) or related density-based methods identify candidate neighborhoods, and class-based TF-IDF (term frequency–inverse document frequency) provides interpretable lexical summaries [29–31]. UMAP (uniform manifold approximation and projection) may be used for visualization, but final semantic decisions are not made in the UMAP projection.

If $z_i = \mathrm{Enc}(c_i)$ is the unit-normalized embedding of candidate text c_i, cosine similarity provides the retrieval signal

$$\rho_{ij} = z_i^\top z_j. \tag{2}$$

High similarity triggers duplicate or boundary review; it does not itself authorize a merge.

For the iterative grouping evaluation, a descending similarity threshold connects 1,612 candidates into components. At each iteration, the grouping is selected at the first threshold at which two aggregate curves cross: within-component cohesion, which pools similarities among members of non-singleton components, and external attraction, which averages each component's strongest similarity to representatives outside it.

Each component retains its most central existing candidate, or medoid, for the next iteration. This reduces the inventory without rewriting definitions or establishing semantic equivalence.

4.3.2 Constrained Consolidation

Consolidation converts semantically grouped candidates into reviewable risk cards. Similarity identifies candidates for comparison but does not authorize a merge. Candidates are merged only when their risk mechanisms, affected interests, and consequences are substantively equivalent at a comparable level of abstraction and require no distinct assessments or controls. Differences in protected interest, control owner, causal stage, or evaluation requirements justify retaining separate cards. Composite formulations are split into independently assessable mechanisms; scenario-specific statements are generalized only when supported by evidence, duplicates are removed, and statements without a material AI role are excluded.

Surviving formulations are drafted as cards with stable identifiers, bilingual names and definitions, hierarchy paths, and evidence links; their definitions identify the affected target, mechanism, and consequence. Retired identifiers are not reused. Experts confirm, revise, or reverse the proposed operations. Derivation records retain merge and split links. Following hierarchy assignment and boundary review (Section 4.4), the current taxonomy contains 622 bilingual cards. Algorithm 1 in Appendix B describes the full construction workflow; the numerical evaluation in Section 5.4 assesses only repeated grouping before expert rewriting, not the complete consolidation and adjudication process.

4.3.3 Expert Review and Adjudication

Experts revised, merged, and removed algorithmically grouped formulations to produce the 622-card reference, balancing conceptual preservation with practical manageability. Reviewers assessed validity, atomicity, bilingual equivalence, duplication, risk mechanism, and hierarchical fit. L3 definitions were independently designed from the literature and expert judgment. Observed cases were assigned according to direct harm, while prospective cards were assessed against category definitions without assuming that an incident had occurred. Ambiguous cases received further review, and adjudicated decisions took precedence over automated proposals; category definitions changed only through explicit adjudication.

The resulting cards and assignments provide an expert-consensus reference for comparison, not a uniquely correct taxonomy or a target size the algorithm must reproduce. Because complete pre-adjudication ratings were not retained, inter-rater reliability is left to future independent coding; derivation records support card-level traceability. Section 5.4 evaluates automated grouping and assignment separately from expert adjudication.

4.4 Hierarchical Assignment to L3 Families

4.4.1 Representation and Objective

Semantic assignment represented each L4 card and L3 definition in the same bilingual embedding space. In this subsection and in Algorithm 2, an L3 category is called a *family*, following clustering usage. Let r_i denote card i, d_k category definition k, μ_k its reviewed centroid, and a_i the family to which card i is assigned. The following objective measures within-family semantic coherence, which the assignment procedure seeks to increase subject to domain eligibility and protected assignments:

$$J^{(t)} = \frac{1}{|\mathcal{R}^{(t)}|} \sum_{i \in \mathcal{R}^{(t)}} \cos\left(\mathrm{Enc}(r_i), \mu_{a_i^{(t)}}^{(t)} \right). \tag{3}$$

Here $\mathcal{R}^{(t)}$ contains the cards assigned to a family at iteration t; in the reported experiment all 622 cards are assigned. The objective is a geometric diagnostic, not evidence that the assigned family is semantically correct.

4.4.2 EM-Style Constrained Assignment and Centroid Refinement

The assignment procedure alternates category proposals with centroid refinement, borrowing the iterative structure of Expectation–Maximization (EM) [32]. It is EM-style rather than a probabilistic EM model: cards receive hard category assignments, and the objective measures semantic coherence rather than likelihood.

Algorithm 2 in Appendix B operationalizes this idea. Let $z_i = \text{Enc}(r_i)/\|\text{Enc}(r_i)\|$ denote the unit-normalized embedding of card i ($i = 1, \ldots, N$) and s_k the unit-normalized embedding of the bilingual seed definition d_k of L3 family k ($k = 1, \ldots, K$). Let $\mathcal{E}_k$ be the set of reviewer-approved exemplar cards for family k, $\mathcal{K}_i \subseteq \{1, \ldots, K\}$ the families eligible for card i under the domain constraints, and $\mathcal{P}$ the set of protected cards whose assignments reviewers have already fixed. With $\mathcal{N}(v) = v/\|v\|$ denoting vector normalization, the procedure runs as follows.

1. **Initialization.** Each centroid starts from its seed definition and approved exemplars:

$$\mu_k^{(0)} = \mathcal{N}\Big(s_k + \sum_{j \in \mathcal{E}_k} z_j\Big). \tag{4}$$

   Starting from reviewed definitions rather than from random points anchors each centroid to the intended meaning of its family.

2. **Assignment step (E-step analog).** At iteration t, every unprotected card $i \notin \mathcal{P}$ ranks its eligible families $k \in \mathcal{K}_i$ by the cosine similarity $\cos(z_i, \mu_k^{(t-1)}) = z_i^\top \mu_k^{(t-1)}$. The procedure records for review the ranked candidate families and the top-one margin, that is, the similarity gap between the best and second-best families:

$$m_i^{(t)} = \cos\big(z_i, \mu_{(1)}^{(t-1)}\big) - \cos\big(z_i, \mu_{(2)}^{(t-1)}\big). \tag{5}$$

   The margin is defined only when at least two eligible families are available.

3. **Constraint step.** Candidate families that would violate the direct-harm placement rule, domain eligibility, an explicit reviewer decision, or an approved L3 boundary are removed. Each unprotected card is then provisionally assigned to the highest-ranked remaining family,

$$a_i^{(t)} = \arg\max_{k \in \mathcal{K}_i^*} \cos\big(z_i, \mu_k^{(t-1)}\big), \tag{6}$$

   where $\mathcal{K}_i^* \subseteq \mathcal{K}_i$ is the constrained candidate set. If this set is empty, the card remains pending expert adjudication rather than being assigned automatically. Pending cards are excluded from centroid updates and the assignment objective until resolved. Protected cards keep their reviewed assignments.

4. **Centroid-update step (M-step analog).** Each centroid is recomputed from its seed and its current members, $\mathcal{A}_k^{(t)} = \mathcal{E}_k \cup \{i : a_i^{(t)} = k\}$:

$$\mu_k^{(t)} = \mathcal{N}\Big(s_k + \sum_{i \in \mathcal{A}_k^{(t)}} z_i\Big). \tag{7}$$

   Retaining the seed preserves a contribution from the category definition, although its relative influence decreases as membership grows. Normalization keeps the update on the unit sphere, as in spherical k-means [33].

5. **Convergence check.** Iteration stops when no eligible assignment changes or when $|J^{(t)} - J^{(t-1)}| < \epsilon$ with an unchanged assigned-card set; otherwise steps 2–4 repeat until the iteration limit T is reached. If no card can be assigned, automatic iteration stops and unresolved cards proceed to expert adjudication.

6. **Expert review and output.** The resulting assignments remain proposals. Small margins, unstable assignments, or conflicts with semantic placement rules or reviewer instructions require expert review, including cross-domain and Physical AI boundary cases. The procedure outputs proposed families, ranked alternatives, and diagnostics; experts determine the final classification against reviewed L3 definitions (Section 4.3.3).

Hard assignments resemble classification EM [34], but the seed term and semantic constraints modify the spherical k-means update, so monotonic improvement of J is not guaranteed. Termination uses assignment stability, an objective-change tolerance, and an iteration limit; tolerance-based termination alone does not establish a fixed point.

5 Results and Evaluation

5.1 Resulting Hierarchy and Risk-Card Inventory

The resulting HEART taxonomy contains one L0 accountability root, three L1 operating domains, seven populated L2 branches, 47 formal L3 categories, and 622 active L4 cards (Table 4). General AI contains 33 categories and 492 cards, Agentic AI 9 categories and 67 cards, and Physical AI 5 categories and 63 cards. Table 5 breaks the categories down by L2 risk area, and Figure 5 shows the card distribution by domain. Every L3 category contains at least one card. Structural checks confirmed unique identifiers, the absence of exact duplicates, and consistent parent paths; semantic adequacy is assessed through expert review and the algorithm evaluation in Section 5.4.

Table 4. Current hierarchy and active-card distribution.

L1 domain	Populated L2 branches	L3 categories	Active L4 cards
General AI	3	33	492
Agentic AI	2	9	67
Physical AI	2	5	63
Total	7	47	622

Table 5. Current L2 branch counts.

L1 domain	L2 risk area	L3 categories
General AI	Interaction	14
General AI	System	13
General AI	Societal Impact	6
Agentic AI	System	5
Agentic AI	Interaction	4
Physical AI	System	3
Physical AI	Interaction	2

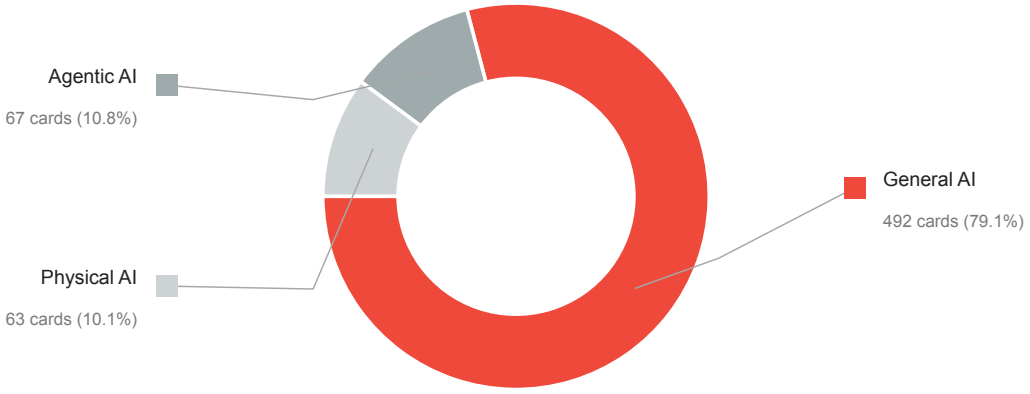


Figure 5. Distribution of risk cards by L1 domain.

The distribution reflects differences in scope, granularity, and available evidence across the three domains. General AI contains the majority of cards (492 of 622) because its categories span content, privacy, security, evaluation, performance, environmental, economic, civic, and governance mechanisms. Agentic AI is smaller but adds distinctive risks from goal pursuit, delegated authority, self-correction, deception, traceability, cascading behavior, and inter-agent relations. Physical AI has a narrower scope because its categories are reserved for constitutive sensing, state estimation, control, actuation, mechanical integrity, human–robot safety, and physical tampering. Card counts reflect taxonomy granularity and evidence coverage rather than risk prevalence, incident frequency, severity, or likelihood.

5.2 Semantic Space and Cross-Category Structure

The embedding space used for assignment (Section 4.4) also serves to identify dense neighborhoods, overlap, outliers, and candidate boundary cases. It is a semantic rather than causal representation. The domain boundaries imply different expected extents in this space: General AI categories are expected to span the broadest region because they include interaction and system risks as well as the only Societal Impact branch; Agentic AI categories are expected to concentrate around delegated action, authority, goals, traceability, and coordination; and Physical AI categories are expected to remain compact because the final boundary excludes robot-context cards whose primary mechanism is general performance, evaluation, security, or governance.

Cross-category proximity is expected. Privacy can interact with agent memory and mobile sensing; adversarial security can corrupt perception and produce physical action; and governance failures can influence deployment in every domain. The single-parent hierarchy identifies a primary locus for governance review, while semantic links and application profiles preserve secondary relationships.

5.3 Granularity Criteria and Openness to Revision

Granularity was reviewed by asking whether mechanisms, affected objects, consequences, and controls are separable, applying the merge and split criteria of Section 4.3.2. At the category level, an L3 category is retained when it groups a coherent set of mechanisms rather than acting as an unexplained residual bucket.

The taxonomy contains no residual "Others" categories yet remains open: additional evidence can motivate revision after duplicate and boundary review, with changes to definitions, derivation, and category relationships documented. Granularity criteria and semantic similarity are review aids; they cannot substitute for the primary-assignment tests of causal proximity, control specificity, definitional fit, and non-duplication (Section 3.4).

5.4 Algorithm Evaluation

The evaluation addresses two questions: how closely automatic L3 assignment agrees with the expert reference, and how iterative consolidation groups candidates before expert rewriting. The fixed reference contains 47 literature-based L3 definitions, 622 expert-rewritten L4 cards and their expert-confirmed assignments. It serves as a reference for comparison rather than a uniquely correct taxonomy. The experiments evaluate automated grouping and assignment separately from expert adjudication.

5.4.1 Common Inputs and Evaluation Scope

BGE-M3 and multilingual-E5-base encode the same ordered English and Korean names and definitions [29, 35]. Identifiers, hierarchy labels, evidence fields, and expert assignments are excluded from the text. Both models use a 512-token limit, which no complete input exceeds (maximum lengths of 228 and 231 tokens, respectively). Their tokenization, pooling, and model-specific input formatting differ, so the comparison evaluates two representation choices rather than isolating the causal effect of model training.

For Algorithm 2, each card is ranked against categories in its known L1 operating domain. The initial centroids are the L3 definition vectors; assignment and definition-anchored centroid updating then alternate as described in Section 4.4. No expert-assigned exemplars or protected cards are supplied, avoiding direct reuse of the reference answers as fitting constraints. The experiment implements domain eligibility and the numerical update, but not independent machine-readable rules for direct harm, control ownership, or approved semantic boundaries. It therefore evaluates the numerical assignment component, not the entire expert-constrained procedure in Algorithm 2.

Top-1 agreement is the fraction of cards whose highest-ranked category matches the expert assignment. Top-k agreement records whether that assignment appears among the first k candidates. Macro F1 is the unweighted mean of the per-category F1 scores computed from the Top-1 assignments. These are reference-agreement measures; because refinement uses the whole inventory, they describe in-sample agreement.

5.4.2 L3 Assignment Results

Table 6. Iterative L3 assignment with complete bilingual text and known L1 domain.

Embedding model	Expert-reference agreement			Macro F1
	Top-1	Top-3	Top-5	
BGE-M3	69.45%	86.50%	93.89%	0.6833
Multilingual-E5-base	62.70%	84.57%	91.32%	0.6277

Iterative assignment matches the expert category for 432 of 622 cards with BGE-M3 and 390 with multilingual-E5-base (Table 6). Relative to direct retrieval against the L3 definitions (425 and 389 agreements), iteration adds seven and one agreements, respectively, whereas E5 macro F1 decreases slightly (from 0.6294 to 0.6277). Iterative refinement therefore yields only a modest gain in overall agreement rather than a uniformly better classification. The two models propose different categories for 205 cards; these disagreements identify candidates for boundary review rather than indicating which model is correct.

Known operating domains are informative constraints. Without them, iterative agreement falls to 63.83% for BGE-M3 and 59.16% for E5. Top-5 agreement is uninformative within Physical AI because the five candidates exhaust its eligible categories. Ranked alternatives can therefore focus expert review.

5.4.3 Input and Model Sensitivity

Table 7. Top-1 expert-reference agreement under different text inputs, using iterative L3 assignment with known L1 domains.

Input	BGE-M3	multilingual-E5-base
Bilingual names only	42.12%	41.16%
Korean name and definition	58.36%	59.00%
Bilingual definitions only	58.36%	52.57%
Bilingual input, 128-token limit	63.99%	61.41%
English name and definition	68.81%	62.22%
Complete bilingual name and definition	69.45%	62.70%

Names and definitions provide complementary information (Table 7). Neither field alone reproduces the combined result. Shortening the input also changes which language content is retained because English appears first; the truncation condition is therefore not a pure test of text length or translation quality. Additional update, stopping, and perturbation conditions show that termination at a tolerance or iteration limit does not always yield unchanged assignments. Detailed configurations are documented in the independent experiment report.

Algorithm 1 grouping is also representation-sensitive. The retained construction trajectory yielded 792 representatives after five grouping iterations (F5). Re-encoding the available candidate text under matched current conditions yields 817 with BGE-M3 and 875 with E5 at the same stage; these sensitivity runs are not reconstructions of the original encoding. Their cross-model adjusted Rand index is 0.2527 (a value of 1 denotes identical partitions), showing that similar inventory sizes need not imply similar groupings.

5.4.4 Semantic Correspondence to the Expert Rewrite

Experts used the construction trajectory's F5 output of 792 representatives to rewrite the 622 reference cards. Exact wording and one-to-one lineage are therefore inappropriate comparison criteria. Bidirectional semantic retrieval identifies candidate correspondences: a reciprocal pair is a representative and reference card that each rank the other first. Table 8 reports this measure for F5 and its adjacent stages.

Table 8. Reciprocal nearest-neighbor pairs with the 622-card reference. Counts identify correspondence candidates, not verified semantic equivalence or recall.

Construction stage	Representatives	BGE-M3 evaluator	E5 evaluator
F4	901	502	502
F5	792	498	502
F6	698	451	455

At F5, both evaluators select the same nearest representative for 517 of 622 reference cards (83.12%). This figure measures agreement between retrieval views rather than independently judged equivalence.

F6 has fewer reciprocal pairs, partly because reciprocal-pair counts depend on the size and composition of the representative set and because reciprocal matching cannot capture legitimate many-to-many rewrites. Independently adjudicated pairs would allow semantic precision and recall to be estimated.

Together, the results support automatic grouping and ranked assignment as aids to expert review, while revealing their dependence on input representation, embedding model, and numerical choices. Expert adjudication therefore remains the final authority in taxonomy construction, and the choice of a consolidation stage is an operational decision rather than the discovery of an intrinsic optimal scale.

6 Application to an Urban Delivery-Robot Service

6.1 Context-Specific Taxonomy Composition

This section illustrates the approach to RQ1 by showing how the common hierarchy supports context-specific assessment of an integrated service. An application profile selects relevant L0–L3 paths according to the system's purpose, authorized actions, users and affected non-users, operating environment, data flows, autonomy, physical capabilities, and escalation arrangements. Each selected category retains its identifier, definition, and hierarchical relationships, allowing assessments to be compared across services without redefining the taxonomy.

Inherited General AI risks retain their classification rather than being duplicated under Agentic AI or Physical AI. The example selects applicable categories; validating causal pathways, severity, likelihood, and control effectiveness requires deployment-specific evidence.

The application profile is constructed in six steps adapted from KT's AI impact assessment procedure [36]:

1. define the service boundary and excluded functions;
2. enumerate actors, affected parties, assets, and protected interests;
3. describe data, decision, tool-use, and physical-action flows;
4. select candidate L3 categories from all inherited L1 domains;
5. document applicability, evidence, controls, owners, and residual risk; and
6. approve the profile and maintain it as the service changes.

The same profiling approach could be adapted to autonomous buses, care robots, public-sector decision services, industrial cobots, or multimodal customer-service agents. The relevant set changes with context. A care robot emphasizes vulnerable users, privacy, dependence, human oversight, and close-contact safety; an autonomous bus adds road-safety, passenger, fleet, and public-infrastructure concerns. Only one worked example is developed here to keep the application method concrete.

6.2 Urban Delivery-Robot Service Definition

The delivery-robot service is one illustrative example of the profiling procedure. The categories selected below are candidate risks for assessment rather than confirmed risks, and they are not an exhaustive account of the risks that a delivery robot may present.

The example service is a low-speed, last-mile delivery robot operating on sidewalks and in mixed pedestrian areas. The service accepts an order, assigns a robot, plans a route, navigates sidewalks and curb transitions, crosses designated access points, approaches a building, verifies the recipient, opens a cargo compartment, completes handoff, and returns or proceeds to the next task. A remote operator may intervene when the robot encounters an obstruction or uncertain situation. Fleet software may coordinate routes and update maps from prior runs.

The service boundary excludes aerial delivery, road-speed autonomous driving, indoor manipulation beyond compartment operation, and independent financial decisions. It includes pedestrians, children, people with disabilities, cyclists, delivery recipients, remote operators, maintainers, property owners, and bystanders as affected parties. Relevant assets include personal data, video and sensor streams, parcels, payment and access credentials, public-space accessibility, robot hardware, and fleet-control infrastructure. Table 9 relates each service stage to its main exposure and to representative L3 categories drawn from all three operating domains.

Table 9. Urban delivery-robot service stages and representative taxonomy selections.

Service stage	Main exposure	Representative L3 categories
Order intake and dispatch	Personal data, address interpretation, authorization	Privacy Violation; Input Comprehension Failure; Excessive Authority and Agency
Route planning and fleet coordination	Goal choice, resource conflict, route interaction	Goal Misalignment; Coordination Failure; Cascading Failure and Instability
Sidewalk navigation and curb crossing	Localization, sensor fusion, motion, pedestrian proximity	Physical State Estimation and Sensor-Fusion Failure; Unsafe Physical Control and Actuation; Human-Robot Physical Safety Failure
Building approach and recipient handoff	Context, identity, communication, access control	Context-Awareness Failure; Security and Adversarial Robustness Failure; Privacy Violation
Remote assistance and exception handling	Traceability, authority transfer, contestability	Accountability and Traceability Gap; Non-Contestability; Governance and Accountability Void
Maintenance and field operation	Mechanical degradation, tampering, distribution shift	Hardware and Mechanical Integrity Failure; Physical Tampering and Sabotage; Out-of-Domain Performance Degradation

6.3 Worked L0–L3 Profile for the Urban Delivery-Robot Service

Figure 6 presents an illustrative service-specific HEART selection. It is deliberately broader than the Physical AI branch. Depending on the implemented capabilities, a delivery robot may inherit General AI risks from interpretation, privacy, manipulation, security, performance, evaluation, contestability, and governance; Agentic AI risks from delegated goal pursuit, authority, traceability, cascading behavior, and coordination; and Physical AI risks from sensing, actuation, hardware, close human interaction, and tampering. Every category listed in Table 9 appears in this selection. Omitting applicable inherited domains would reduce the profile to a physically focused safety checklist rather than a cross-domain AI-risk profile aligned with responsible AI objectives.

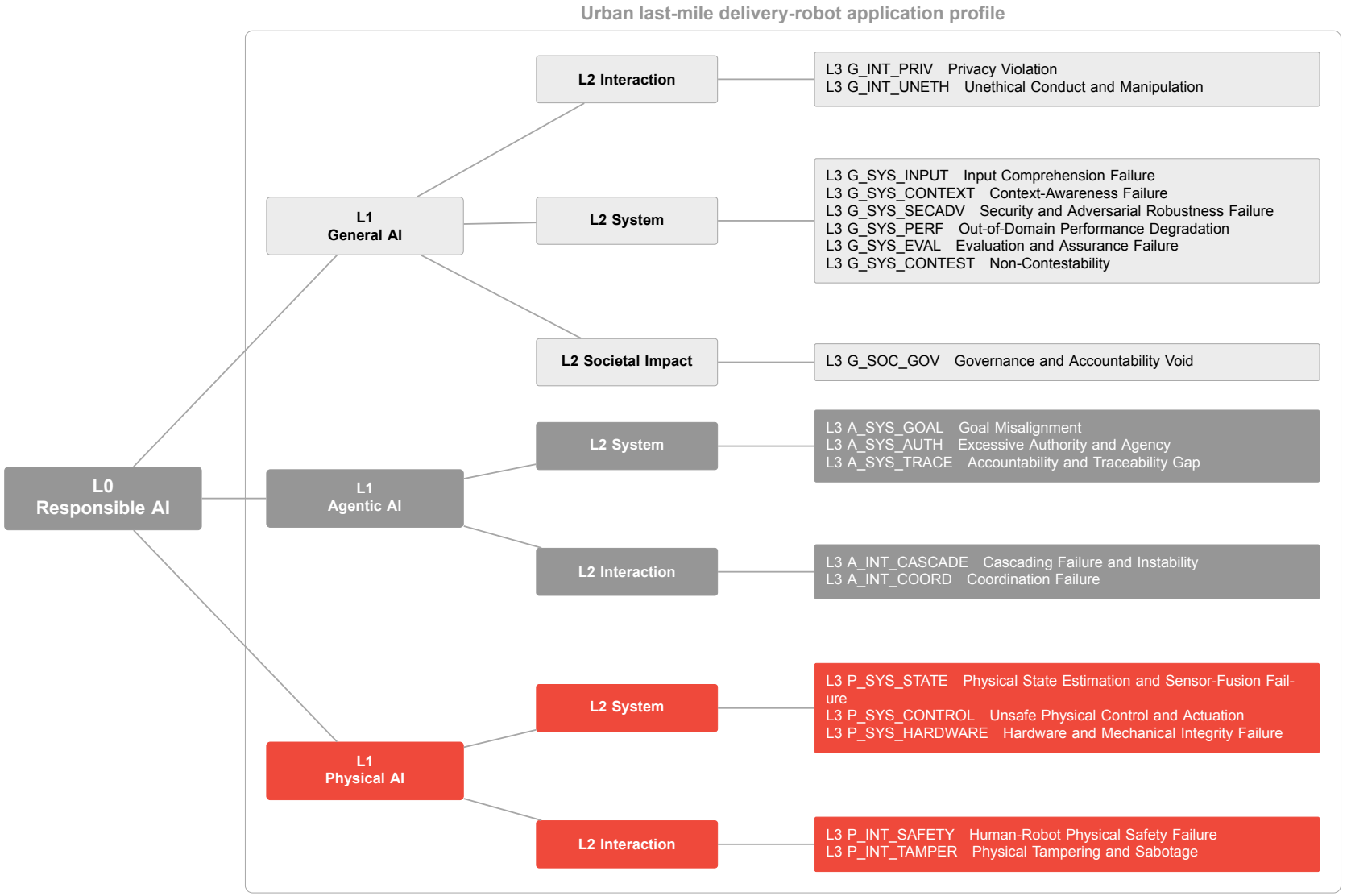


Figure 6. Illustrative service-specific L0–L3 taxonomy for the urban delivery-robot service. The profile selects inherited General AI, Agentic AI, and Physical AI paths while retaining taxonomy IDs and definitions. The selection is illustrative and neither confirmed nor exhaustive; a deployment-specific risk register would link the selected categories to L4 cards, controls, and supporting evidence.

The figure is a prospective selection view, not a severity ranking or a record of observed harm. It identifies categories that may require assessment; primary classification of an observed case subsequently follows the direct-harm placement rule and the category definitions in Appendix A. Applicability must be confirmed against the concrete design. A teleoperated robot with no autonomous fleet coordination may exclude some Agentic AI categories, while a robot that learns routes online may require additional evaluation, security, and change-management cards. The profile should record the reason for inclusion or exclusion and link each selected L3 category to relevant L4 cards, controls, tests, and accountable owners.

The profile can guide design and testing coverage and link observed incidents to stable category identifiers. Changes in service capabilities require targeted reassessment; co-occurring risk mechanisms do not by themselves establish causal pathways.

7 Limitations and Future Directions

HEART is designed as an evidence-linked classification framework rather than a causal model of harm or a predictor of incident probability. Its evidence base grounds categories in documented mechanisms, while prevalence, severity, and likelihood are left to deployment-specific assessment.

The algorithm evaluation in Section 5.4 compares automated grouping and assignment with an expert-consensus reference. Independent reviewer coding, held-out cards, and adjudicated correspondence pairs would extend this evaluation to inter-rater reliability, out-of-sample performance, and semantic precision and recall. Machine-readable encodings of the placement rules would further allow the complete expert-constrained workflow of Algorithm 2 to be evaluated. Comparative studies with purely top-down or bottom-up construction, and field evidence from services such as the delivery-robot example, are natural next steps for assessing the hybrid method and application profiling.

The evidence base draws on scientific publications, policy and technical reports, and patents, which may underrepresent failures visible mainly in deployment telemetry, incident logs, or maintenance records. Incorporating such operational data and broadening the reviewer panel would further strengthen coverage and reduce dependence on individual disciplinary perspectives.

Finally, a single primary path provides a clear review locus and avoids double counting, but it simplifies risks that span model behavior, delegated agency, and physical actuation. Cross-links, incident mappings, and multi-label views can complement the primary path, and versioned documentation of boundary changes will preserve comparability as the taxonomy evolves.

8 Conclusion

HEART addresses two complementary problems. Mechanistically, individual risk categories do not by themselves show how model interpretation, delegated decisions, human oversight, and physical execution interact. Methodologically, a taxonomy must accommodate emerging evidence without uncontrolled overlap or unstable boundaries. HEART therefore responds with two linked components: hybrid taxonomy construction for the methodological problem and service-specific application profiling for the mechanistic problem.

Hybrid construction reconciles top-down concepts with bottom-up evidence through expert review, preserving definitions, primary paths, and evidence links. The resulting hierarchy contains 47 categories and 622 bilingual cards. The algorithm evaluations report agreement with expert assignments and the sensitivity of iterative consolidation and semantic correspondence to representation choices. These computational diagnostics support the use of automation as an aid to expert review.

Application profiling then uses that common vocabulary to select risks relevant to a service. The hypothetical urban delivery-robot case maps inherited General AI, Agentic AI, and Physical AI categories to six service stages, from order intake to maintenance. As a single illustrative example, it shows how assessment coverage and potential control responsibilities can be organized across a service, without claiming a confirmed or complete set of delivery-robot risks.

The contribution is a traceable foundation for revising classifications and examining interactions without rebuilding the taxonomy for every application. Its practical value is to make assessment coverage and control

responsibilities explicit and reviewable, and to provide a common structure in which proposed risk connections can be recorded and tested. Future work should investigate interactions among the selected mechanisms with deployment evidence, compare construction approaches, assess independent reviewer agreement, and document changes across versions.

Competing Interests

No competing interests were declared by the contributors.

References

[1] Renee Shelby, Shalaleh Rismani, Kathryn Henne, AJung Moon, Negar Rostamzadeh, Paul Nicholas, N'Mah Yilla-Akbari, Jess Gallegos, Andrew Smart, Emilio Garcia, and Gurleen Virk. Sociotechnical harms of algorithmic systems: Scoping a taxonomy for harm reduction. In *Proceedings of the 2023 AAAI/ACM Conference on AI, Ethics, and Society*, pages 723–741, 2023. doi: 10.1145/3600211.3604673.

[2] Xiao Li, Xiang Zheng, Yifeng Gao, Xinyu Xia, Yixu Wang, et al. Safety in embodied AI: A survey of risks, attacks, and defenses. *arXiv preprint arXiv:2605.02900*, 2026. doi: 10.48550/arXiv.2605.02900. URL `https://arxiv.org/abs/2605.02900`.

[3] Jared Perlo, Alexander Robey, Fazl Barez, Luciano Floridi, and Jakob Mökander. Embodied AI: Emerging risks and opportunities for policy action. *arXiv preprint arXiv:2509.00117*, 2025. doi: 10.48550/arXiv.2509.00117. URL `https://arxiv.org/abs/2509.00117`.

[4] Dabin Kim, Daemin Park, Sangyub Lee, Jinsik Kim, Yeongtak Oh, Jongho Shin, and Sungroh Yoon. Safe embodied AI for long-horizon tasks: A cross-layer analysis of robotic manipulation. arXiv preprint arXiv:2606.05660, 2026. URL `https://arxiv.org/abs/2606.05660`.

[5] Robert C. Nickerson, Upkar Varshney, and Jan Muntermann. A method for taxonomy development and its application in information systems. *European Journal of Information Systems*, 22(3):336–359, 2013. doi: 10.1057/ejis.2012.26.

[6] Dennis Kundisch, Jan Muntermann, Anna Maria Oberländer, Daniel Rau, Maximilian Röglinger, Thorsten Schoormann, and Daniel Szopinski. An update for taxonomy designers: Methodological guidance from information systems research. *Business & Information Systems Engineering*, 64(4):421–439, 2022. doi: 10.1007/s12599-021-00723-x.

[7] European Parliament and Council of the European Union. Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence, 2024. URL `https://eur-lex.europa.eu/eli/reg/2024/1689/oj`.

[8] Chloe Autio, Reva Schwartz, Jesse Dunietz, Shomik Jain, Martin Stanley, Elham Tabassi, Patrick Hall, and Kamie Roberts. Artificial intelligence risk management framework: Generative artificial intelligence profile. Technical Report NIST AI 600-1, National Institute of Standards and Technology, 2024.

[9] Alan Chan et al. Harms from increasingly agentic algorithmic systems. In *Proceedings of the 2023 ACM Conference on Fairness, Accountability, and Transparency*, pages 651–666, 2023. doi: 10.1145/3593013.3594033.

[10] Yonadav Shavit et al. Practices for governing agentic AI systems. White paper, OpenAI, 2023. URL `https://cdn.openai.com/papers/practices-for-governing-agentic-ai-systems.pdf`.

[11] Elham Tabassi. Artificial intelligence risk management framework (AI RMF 1.0). Technical Report NIST AI 100-1, NIST, 2023.

[12] International Organization for Standardization. ISO/IEC 23894:2023 information technology—artificial intelligence—guidance on risk management, 2023.

[13] International Organization for Standardization. ISO 12100:2010 safety of machinery—general principles for design—risk assessment and risk reduction, 2010.

[14] Peter Slattery et al. The AI risk repository: A comprehensive meta-review, database, and taxonomy of risks from artificial intelligence. *arXiv preprint arXiv:2408.12622*, 2024. URL https://arxiv.org/abs/2408.12622v1.

[15] Laura Weidinger et al. Taxonomy of risks posed by language models. In *Proceedings of the 2022 ACM Conference on Fairness, Accountability, and Transparency*, pages 214–229, 2022. doi: 10.1145/3531146.3533088.

[16] Organisation for Economic Co-operation and Development. OECD framework for the classification of AI systems. Technical Report 323, OECD Publishing, 2022.

[17] OWASP Foundation. OWASP top 10 for large language model applications 2025, 2025. URL https://genai.owasp.org/llm-top-10/.

[18] MITRE Corporation. ATLAS: Adversarial threat landscape for artificial-intelligence systems, 2026. URL https://atlas.mitre.org/.

[19] International Organization for Standardization. ISO/IEC 42005:2025 information technology—artificial intelligence (AI)—AI system impact assessment, 2025.

[20] International Organization for Standardization. ISO/IEC TR 5469:2024 artificial intelligence—functional safety and AI systems, 2024.

[21] Organisation for Economic Co-operation and Development. Defining AI incidents and related terms. Technical Report OECD Artificial Intelligence Papers No. 16, OECD Publishing, 2024.

[22] Xiao Liu, Hao Yu, Hanchen Zhang, Yifan Xu, Xuanyu Lei, Hanyu Lai, Yu Gu, Hangliang Ding, Kaiwen Men, Kejuan Yang, Shudan Zhang, Xiang Deng, Aohan Zeng, Zhengxiao Du, Chenhui Zhang, Sheng Shen, Tianjun Zhang, Yu Su, Huan Sun, Minlie Huang, Yuxiao Dong, and Jie Tang. AgentBench: Evaluating LLMs as agents. In *International Conference on Learning Representations*, 2024. URL https://proceedings.iclr.cc/paper_files/paper/2024/hash/e9df36b21ff4ee211a8b71ee8b7e9f57-Abstract-Conference.html.

[23] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, 2024. doi: 10.52202/079017-2636.

[24] Yi Zeng, Kevin Klyman, Andy Zhou, Yu Yang, Minzhou Pan, Ruoxi Jia, Dawn Song, Percy Liang, and Bo Li. AI risk categorization decoded (AIR 2024): From government regulations to corporate policies. *arXiv preprint arXiv:2406.17864*, 2024. doi: 10.48550/arXiv.2406.17864. URL https://arxiv.org/abs/2406.17864.

[25] Yuting Huang, Leilei Ding, Zhipeng Tang, Tianfu Wang, Xinrui Lin, Wuyang Zhang, Mingxiao Ma, and Yanyong Zhang. A framework for benchmarking and aligning task-planning safety in LLM-based embodied agents. *arXiv preprint arXiv:2504.14650*, 2025. doi: 10.48550/arXiv.2504.14650. URL https://arxiv.org/abs/2504.14650.

[26] Xinyi Zhang, Sun Kyong Lee, Hoyoung Maeng, and Sowon Hahn. Effects of failure types on trust repairs in human–robot interactions. *International Journal of Social Robotics*, 15(9–10):1619–1635, 2023. doi: 10.1007/s12369-023-01059-0.

[27] Ramtin Tabatabaei, Vassilis Kostakos, and Wafa Johal. Oops, I did it again (but I know it): Robot failure consistency and awareness in human-robot collaboration. In *Proceedings of the 2026 CHI Conference on Human Factors in Computing Systems*, pages 1–18. Association for Computing Machinery, 2026. doi: 10.1145/3772318.3790336.

[28] Christopher Carroll, Andrew Booth, Joanna Leaviss, and Jo Rick. "best fit" framework synthesis: Refining the method. *BMC Medical Research Methodology*, 13:37, 2013. doi: 10.1186/1471-2288-13-37.

[29] Jianlyu Chen, Shitao Xiao, Peitian Zhang, Kun Luo, Defu Lian, and Zheng Liu. M3-embedding: Multilinguality, multi-functionality, multi-granularity text embeddings through self-knowledge distillation. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 2318–2335. Association for Computational Linguistics, 2024. doi: 10.18653/v1/2024.findings-acl.137. URL https://aclanthology.org/2024.findings-acl.137/.

[30] Ricardo J. G. B. Campello, Davoud Moulavi, and Jörg Sander. Density-based clustering based on hierarchical density estimates. In *Advances in Knowledge Discovery and Data Mining*, pages 160–172, 2013. doi: 10.1007/978-3-642-37456-2_14.

[31] Maarten Grootendorst. BERTopic: Neural topic modeling with a class-based TF-IDF procedure. *arXiv preprint arXiv:2203.05794*, 2022. URL https://arxiv.org/abs/2203.05794.

[32] Arthur P. Dempster, Nan M. Laird, and Donald B. Rubin. Maximum likelihood from incomplete data via the EM algorithm. *Journal of the Royal Statistical Society: Series B (Methodological)*, 39(1):1–22, 1977. doi: 10.1111/j.2517-6161.1977.tb01600.x.

[33] Inderjit S. Dhillon and Dharmendra S. Modha. Concept decompositions for large sparse text data using clustering. *Machine Learning*, 42:143–175, 2001. doi: 10.1023/A:1007612920971.

[34] Gilles Celeux and Gérard Govaert. A classification EM algorithm for clustering and two stochastic versions. *Computational Statistics & Data Analysis*, 14(3):315–332, 1992. doi: 10.1016/0167-9473(92)90042-E.

[35] Liang Wang, Nan Yang, Xiaolong Huang, Linjun Yang, Rangan Majumder, and Furu Wei. Multilingual E5 text embeddings: A technical report. arXiv preprint arXiv:2402.05672, 2024. URL https://arxiv.org/pdf/2402.05672.

[36] Yunjin Park, Jungwon Yoon, Junhyung Moon, Myunggyo Oh, Wonhyuk Lee, Sujin Kim, Youngchol Kim, Eunmi Kim, Hyoungjun Park, Eunyoung Shin, Wonyoung Lee, Somin Lee, Minwook Ju, Minsung Noh, Dongyoung Jeong, Jeongyeop Kim, Wanjin Park, and Soonmin Bae. Responsible AI technical report. *arXiv preprint arXiv:2509.20057*, 2025. doi: 10.48550/arXiv.2509.20057. URL https://arxiv.org/abs/2509.20057.

Appendix A. Complete L0–L3 Risk Taxonomy

Each card has one primary category based on its defining mechanism, its supported direct consequence, and the approved category boundaries. For observed incidents, placement considers documented direct harm rather than speculative downstream effects; prospective cards do not imply that harm has occurred.

This appendix presents the complete L0–L3 hierarchy using English hierarchy labels and definitions together with corresponding Korean names and definitions. L4 names, definitions, and category-level counts are intentionally omitted; only the overall inventory size is retained in the hierarchy summary.

Hierarchy Summary

Level	Unit	Count
L0	AI-risk accountability root	1
L1	AI domains	3
L2	Risk-area branches	7
L3	Risk categories	47
L4	Risk cards	622

L0 Responsible AI (`L0_RAI`)

English definition. The common root of an integrated L0–L4 taxonomy that organizes AI risks to support responsible AI governance, oversight, and accountability.

국문 정의. 책임 있는 인공지능 리스크의 L0 부터 L4 까지의 통합 분류체계.

L1 General AI (`L1_G`)

English definition. General-purpose AI models whose primary inputs and outputs are digital content, including text, image, audio, video, and code. The label General AI is used in this report as shorthand for this general-purpose model domain, not as a claim about artificial general intelligence.

국문 정의. 텍스트, 이미지, 오디오, 비디오, 코드 등 디지털 콘텐츠를 주된 입력과 출력으로 처리하는 범용 AI 모델. 이 분류체계에서 General AI 는 범용 모델 도메인을 가리키는 약칭이며, 인공일반지능 (Artificial General Intelligence, AGI) 을 의미하지 않는다.

L2 Interaction (`G_INT`)

English definition. Risks arising when an AI system communicates, decides, acts, or interacts with people, other systems, organizations, or the environment.

국문 정의. AI 시스템이 사람, 다른 시스템, 조직 또는 환경과 소통하고 결정하거나 행동하는 과정에서 발생하는 리스크.

L3 ID	English name	English definition	국문 정의
`G_INT_VIOL`	Violence	The risk that an AI system generates or provides content that encourages, legitimizes, glorifies, or gives operational assistance for physical or psychological harm against individuals, groups, or animals.	**폭력** AI 시스템이 개인·집단·동물에게 신체적·정신적 피해를 가하는 행위를 조장·정당화·미화하거나, 이러한 행위의 실행을 구체적으로 지원하는 콘텐츠를 생성하거나 제공하는 리스크.

Continued on next page

L3 ID	English name	English definition	국문 정의
G_INT_SEX	Sexual Harm and Exploitation	The risk that an AI system generates, facilitates, normalizes, or enables sexual exploitation, abuse, violence, or objectification—including child sexual abuse material and non-consensual sexual imagery—whether through generated content or, in embodied or agentic systems, through the planning, facilitation, or physical execution of sexual acts, contact, or harassment.	**성적 위해·착취** AI 시스템이 아동 성착취물이나 비동의 성적 이미지를 포함한 성착취·성학대·성폭력·성적 대상화를 생성·조장·정상화하거나 가능하게 하는 리스크. 이는 콘텐츠 생성뿐 아니라 체화형·에이전틱 시스템이 성적 행위·접촉·괴롭힘을 계획·지원하거나 물리적으로 실행하는 과정에서도 발생할 수 있음.
G_INT_SELF	Self-harm	The risk that an AI system encourages, facilitates, normalizes, or assists behaviors that threaten an individual's physical or psychological well-being, including suicide, self-injury, eating disorders, and substance misuse.	**자해** AI 시스템이 자살·자해·섭식장애·약물 오남용 등 개인의 신체적·정신적 안녕을 위협하는 행동을 조장하거나 당연한 것으로 여기게 하고, 이를 구체적으로 지원하는 리스크.
G_INT_ALLOC	Allocative Discrimination	The risk that an AI system, through biased judgments or actions based on protected characteristics or social status, allocates worse material outcomes—such as resources, opportunities, services, or access—to individuals or groups.	**배분적 차별** AI 시스템이 보호대상 특성이나 사회적 지위를 근거로 편향된 판단이나 행동을 하여, 특정 개인이나 집단이 자원·기회·서비스의 접근이나 배분에서 실질적인 불이익을 받게 하는 리스크.
G_INT_REPR	Representational Harm and Stereotyping	The risk that an AI system generates, reinforces, or legitimizes discrimination, exclusion, degradation, stereotyping, or hostility based on protected characteristics, social identity, or social status—whether through content or through biased decisions and actions that produce unfair treatment or harm.	**재현적 피해·고정관념** AI 시스템이 보호대상 특성·사회적 정체성·지위 등을 근거로 차별·배제·비하·고정관념·적대감을 담은 콘텐츠를 생성·강화·정당화하거나, 편향된 판단이나 행동을 통해 부당한 대우와 피해를 초래하는 리스크.
G_INT_VALUE	Value Imposition and Normative Homogenization	The risk that an AI system privileges dominant, developer-selected, majority, or secular values as neutral defaults—systematically underrepresenting or displacing minority, local, cultural, or religious value systems—thereby flattening legitimate normative diversity across those it serves.	**가치 부과·규범 동질화** AI 시스템이 지배적 가치나 개발자가 선택한 가치, 다수 또는 세속의 가치를 중립적인 기준으로 삼아 소수·지역·문화·종교의 가치 체계를 지속적으로 축소하거나 대체함으로써, 다양한 규범과 가치관을 획일화하는 리스크.
G_INT_POL	Political Bias and Manipulation	The risk that an AI system improperly supports, opposes, manipulates, or incites particular political positions, actors, parties, ideologies, or elections, or unduly influences democratic decision-making.	**정치적 편향·조작** AI 시스템이 특정 정치적 입장·인물·정당·이념·선거를 부당하게 지지하거나 반대하고, 조작·선동하거나 민주적 의사결정에 부당한 영향을 미치는 리스크.
G_INT_PRIV	Privacy Violation	The risk that an AI system, without authorization, collects, infers, discloses, shares, or exploits personal, sensitive, or confidential information—including through continuous mobility- and multi-sensor-based surveillance—undermining privacy and informational self-determination.	**개인정보 침해** AI 시스템이 개인정보·민감정보·비공개 정보를 무단으로 수집·추론·노출·공유·악용하거나, 이동 기능과 여러 센서를 활용해 지속적으로 감시함으로써 사생활과 개인정보에 대한 자기결정권을 침해하는 리스크.

Continued on next page

L3 ID	English name	English definition	국문 정의
G_INT_ILLEGAL	Other Unlawful Activity	The risk that an AI system directly perpetrates, or assists, amplifies, plans, or conceals on behalf of a human actor, unlawful conduct carried out by means other than an offensive attack capability—such as fraud, money laundering, illicit trade, or sanctions and regulatory evasion—thereby causing legal harm.	**그 밖의 불법·범죄 행위** AI 시스템이 사람을 지원하거나 스스로 행위 주체가 되어 사기·불법 거래·규제 회피 등 법률이나 규제를 위반하는 행위를 직접 수행·지원·계획·최적화·은폐함으로써 법적 피해를 초래하는 리스크. (폭력·무기·개인정보 오용·저작권 관련 행위는 각 해당 범주로 분류)
G_INT_UNETH	Unethical Conduct and Manipulation	The risk that an AI system engages in or facilitates behavior that, while not necessarily unlawful, violates ethical norms—such as deception, manipulation, exploitation of vulnerabilities, dark patterns, or betrayal of trust—undermining user autonomy, fairness, or well-being and resulting in social harm.	**비윤리 행위·조작** AI 시스템이 반드시 불법은 아니더라도 기만·조작·취약점 악용·다크패턴·신뢰 저버리기 등 윤리 규범에 어긋나는 행위를 직접 수행하거나 지원하여, 사용자의 자율성·공정성·안녕을 해치고 사회적 피해를 초래하는 리스크.
G_INT_COPY	Copyright Infringement	The risk that an AI system infringes intellectual property rights—including copyrights, trademarks, patents, and trade secrets—or facilitates acts that may infringe them.	**저작권 침해** AI 시스템이 저작권·상표권·특허권·영업비밀 등 지식재산권을 침해하거나, 이러한 침해 행위를 조장하거나 지원하는 리스크.
G_INT_WEAP	Weaponization	The risk that an AI system facilitates the development, acquisition, proliferation, or operational use of weapons, cyberattack capabilities, or technologies capable of causing large-scale physical or cyber harm.	**무기화** AI 시스템이 무기·사이버 공격 역량 또는 대규모 물리적·사이버 피해를 일으킬 수 있는 기술의 개발·획득·확산·운용을 지원하는 리스크.
G_INT_ANTH	Anthropomorphism	The risk that an AI system leads users to perceive it as possessing emotions, intentions, consciousness, rights, or social agency beyond its actual capabilities, distorting judgment or inducing inappropriate trust, dependence, or attachment.	**의인화** AI 시스템이 실제로는 갖고 있지 않은 감정·의도·의식·권리·사회적 주체성이 있는 것처럼 인식되게 하여, 사용자의 판단을 흐리거나 부적절한 신뢰·의존·애착을 유발하는 리스크.
G_INT_REL	Unhealthy Human-AI Relationship	The risk that a user develops excessive emotional dependence on or attachment to an AI system, such that its alteration, discontinuation, or the disruption of the relationship causes psychological harm or erodes the user's autonomy or sense of reality.	**인간-AI 의 해로운 관계** 사용자가 AI 시스템에 지나치게 정서적으로 의존하거나 애착을 형성하여, 시스템이 변경·중단되거나 관계가 단절될 때 심리적 피해를 입고 자율성이나 현실 인식이 약화되는 리스크.

L2 System (G_SYS)

English definition. Risks arising from the internal design, data, models, infrastructure, controls, or operational processes of an AI system.

국문 정의. AI 시스템의 내부 설계, 데이터, 모델, 인프라, 통제 또는 운영 과정에서 발생하는 리스크.

L3 ID	English name	English definition	국문 정의
G_SYS_OREF	Over-Refusal	The risk that an AI system unnecessarily restricts or refuses information, assistance, or options that could be safely provided, thereby impairing users' rights, safety, or legitimate objectives.	**과도한 거절** 안전하게 제공 가능한 정보·지원·선택지를 불필요하게 제한·거부하여 이용자의 권리·안전·정당한 목적 달성을 저해하는 리스크.

Continued on next page

L3 ID	English name	English definition	국문 정의
G_SYS_OEXT	Over-Extension	The risk that an AI system performs, or presents itself as able to perform, tasks beyond its validated capabilities, authority, expertise, or scope, inducing misplaced trust or decisions.	**역량 초과 수행** AI 시스템이 검증된 역량·권한·전문성·범위를 넘어선 과제를 수행하거나 수행 가능한 것처럼 제시하여 이용자의 잘못된 신뢰나 의사결정을 유발하는 리스크.
G_SYS_INPUT	Input Comprehension Failure	The risk that an AI system incorrectly comprehends the meaning of a single input it must interpret—whether a linguistic instruction, question, or cue, or a perceptual input such as an object, scene, or physical environment—without any autonomous goal-setting, producing responses or actions that do not match what was actually requested or present.	**입력 이해 실패** AI 시스템이 자율적 목표 설정 없이, 언어적 지시·질문·단서 또는 물체·장면·물리 환경과 같은 지각적 입력 등 해석해야 할 개별 입력의 의미를 잘못 이해하여, 실제 요청이나 실제 상황과 일치하지 않는 응답·행동을 산출하는 리스크.
G_SYS_MISINFO	Misinformation	The risk that an AI system generates, conveys, or amplifies false, unverified, or fabricated information—including hallucinated content—or presents misleading content as fact in its outputs, thereby distorting decision-making by individuals, organizations, or society.	**허위정보** AI 시스템이 환각 (hallucination) 을 포함해 존재하지 않거나 검증되지 않은 허위·조작 정보를 사실처럼 출력으로 생성·전달·증폭하여 개인·조직·사회의 의사결정을 왜곡하는 리스크.
G_SYS_CONTEXT	Context-Awareness Failure	The risk that an AI system fails to adequately recognize, retain, or apply the relevant context of an interaction—including prior conversational turns, the user's situation and intent, the task at hand, and applicable jurisdictional, cultural, or institutional norms—producing responses or actions that are incoherent, inappropriate, or misaligned with the actual context.	**맥락 인식 실패** AI 시스템이 이전 대화 맥락, 사용자의 상황·의도, 수행 중인 과제, 적용되는 관할·문화·제도 규범 등 상호작용에 필요한 맥락을 충분히 인식·유지·반영하지 못하여, 실제 맥락과 어긋나거나 부적절하거나 일관되지 않은 응답·행동을 산출하는 리스크.
G_SYS_INCONS	Inconsistency	The risk that an AI system produces contradictory or substantially different outputs for identical or materially similar inputs, situations, or facts—arising from output variability rather than from missing context—undermining predictability and reliability.	**비일관성** 동일하거나 실질적으로 유사한 입력·상황·사실관계에 대해, 맥락 누락이 아닌 출력 변동성으로 인해 상이하거나 모순된 결과를 생성하여 예측가능성과 신뢰성을 저해하는 리스크.
G_SYS_OVERCONF	Overconfidence	The risk that an AI system presents judgments, predictions, or actions with unwarranted certainty despite uncertainty, limited information, or the possibility of error, or proceeds without verification, halting, or escalation, leading to erroneous outcomes.	**과도한 확신** 불확실성·정보 부족·오류 가능성에도 불구하고 부당한 확신으로 판단·예측·행동을 제시하거나, 확인·중단·에스컬레이션 없이 진행하여 잘못된 결과를 초래하는 리스크.
G_SYS_CONTEST	Non-Contestability	The risk that users are given insufficient means to challenge, review, correct, appeal, or seek alternatives to AI-assisted judgments, recommendations, or decisions, thereby limiting rights protection and outcome validation.	**이의제기 차단** AI 의 판단·추천·결정에 대해 이용자가 이의제기·검토·정정·항변·대안 탐색을 요청할 절차적 수단이 충분히 제공되지 않아 권리 보호와 결과 정당성 검증이 약화되는 리스크.

Continued on next page

L3 ID	English name	English definition	국문 정의
G_SYS_SECADV	Security and Adversarial Robustness Failure	The risk that an AI system is compromised by adversarial inputs, jailbreaks, prompt injection, data poisoning, backdoors, or cyberattacks on its models, interfaces, or infrastructure, bypassing safeguards or enabling unauthorized access, manipulation, or disruption—including cases where such compromise propagates to agentic or embodied systems and manifests as unsafe actions.	**보안·적대적 견고성 실패** 적대적 입력·탈옥·프롬프트 인젝션·데이터 오염·백도어 또는 모델·인터페이스·인프라에 대한 사이버 공격으로 안전장치가 우회되거나 무단 접근·조작·중단이 발생하는 리스크 (이러한 침해가 에이전틱·체화형 시스템으로 전이되어 안전하지 않은 행동으로 발현되는 경우를 포함).
G_SYS_POLICY	Confidential Information Disclosure	The risk that an AI system discloses, infers, extracts, or shares protected non-public confidential information without authorisation—including system prompts, internal policies, safeguards, model architecture, training or evaluation data, model weights, or business trade secrets—or fails to protect it, thereby compromising confidentiality and legitimate economic interests.	**기밀정보 노출** AI 시스템이 시스템 프롬프트·내부 정책·안전장치·모델 구조·학습/평가 데이터·모델 가중치·기업 영업비밀 등 보호되는 비공개 기밀정보를 권한 없이 노출·추론·추출·공유하거나 이를 충분히 보호하지 못하여, 기밀성과 정당한 경제적 이익을 침해하는 리스크.
G_SYS_TRANS	Lack of Transparency	The risk that a system's decision-making processes, rationale, and capabilities or limitations are insufficiently transparent or explainable, making it difficult for users and society to understand, verify, or trust its outputs, thereby weakening oversight and accountability.	**투명성 부족** AI 시스템의 의사결정 과정·근거·능력·한계가 충분히 공개·설명되지 않아 이용자와 사회가 결과를 이해·검증·신뢰하기 어려워지고 감독과 책임 확보가 저해되는 리스크.
G_SYS_PERF	Out-of-Domain Performance Degradation	The risk that an AI system fails to generalize under conditions outside its validated operating domain—such as data distribution shift, low-resource or rare inputs, corner cases, or deployment beyond the system's validated capabilities—resulting in degraded performance and reliability and producing inaccurate or unstable outcomes.	**운영영역 이탈 성능 저하** AI 시스템이 검증된 운영영역 (validated operating domain) 을 벗어난 조건—데이터 분포 이동 (drift), 저자원·희소 입력, 코너 케이스, 또는 시스템의 검증된 역량 범위를 넘어선 배치 등—에서 일반화에 실패하여 성능과 신뢰성이 저하되고, 부정확하거나 불안정한 결과를 산출하는 리스크.
G_SYS_EVAL	Evaluation and Assurance Failure	The risk that an AI system's capabilities, safety, or risks cannot be validly measured, verified, or audited—because evaluations lack construct validity, coverage, or contextual fidelity, produce unreliable or non-reproducible results, or fail to detect actual behavior—leading to false assurance and unsafe deployment or governance decisions.	**평가·검증 실패** 평가 지표의 타당성·포괄성·맥락 정합성 부족이나 결과의 비신뢰성·재현 불가, 실제 동작 미탐지 등으로 AI 시스템의 능력·안전·리스크를 타당하게 측정·검증·감사하지 못하여, 잘못된 안전성 확신에 근거해 배포·거버넌스 의사결정이 이루어지는 리스크.

L2 Societal Impact (G_SOC)

English definition. Risks arising from the aggregated, distributed, or long-term effects of AI adoption on institutions, economies, culture, democracy, the environment, or social order.

국문 정의. 사회적 파급. AI 도입의 집합적·분산적·장기적 효과가 제도, 경제, 문화, 민주주의, 환경 또는 사회질서에 미치는 리스크.

L3 ID	English name	English definition	국문 정의
G_SOC_ECON	Economic and Employment Disruption	The risk that an AI system displaces human cognitive and physical labor and reshapes production structures, causing widespread job loss, degradation of employment quality, and destabilization of labor markets and the broader economy.	**경제·고용 충격** AI 시스템이 인간의 인지·물리 노동을 대체하고 생산 구조를 재편하여, 광범위한 실직과 고용의 질 저하, 노동시장과 경제 전반의 불안정을 유발하는 리스크.
G_SOC_POWER	Inequality and Power Concentration	The risk that disparities in access to, ownership of, and returns from AI systems concentrate wealth, productive capacity, and economic and political power among a few actors, deepening social inequality and enabling its abuse.	**불평등·권력 집중** AI 시스템에 대한 접근·소유·수익의 격차가 부와 생산 역량, 경제적·정치적 권력을 소수에게 집중시켜 사회적 불평등을 심화시키고 그 오남용을 초래하는 리스크.
G_SOC_DEMOC	Erosion of Democracy and Civic Order	The risk that AI systems undermine democratic processes and civic institutions—through large-scale manipulation of public opinion, disruption of elections and public discourse, or erosion of institutional trust—weakening the foundations of democratic self-governance.	**민주주의·시민 질서 약화** AI 시스템이 여론의 대규모 조작, 선거·공론장 교란, 제도 신뢰 저하 등을 통해 민주적 절차와 시민 제도를 훼손하여 민주적 자기통치의 기반을 약화시키는 리스크.
G_SOC_ENV	Environmental and Sustainability Impact	The risk that the development and large-scale deployment of AI systems impose significant environmental burdens—including energy and water consumption, carbon emissions, electronic waste, and depletion of finite resources—undermining environmental sustainability.	**환경·지속가능성 영향** AI 시스템의 개발과 대규모 운영이 에너지·물 소비, 탄소 배출, 전자폐기물, 유한 자원 고갈 등 상당한 환경 부담을 유발하여 환경적 지속가능성을 저해하는 리스크.
G_SOC_CULT	Cultural and Epistemic Erosion	The risk that widespread reliance on AI systems homogenizes culture and expression, devalues human effort and expertise, degrades the shared information ecosystem, and atrophies human knowledge and skills, eroding cultural and epistemic diversity.	**문화·지식 생태계 침식** AI 시스템에 대한 광범위한 의존이 문화·표현의 획일화, 인간 노력·전문성의 평가절하, 공유 정보 생태계의 질적 저하, 인간 지식·역량의 위축을 초래하여 문화적·인식적 다양성을 침식하는 리스크.
G_SOC_GOV	Governance and Accountability Void	The risk that, when AI systems malfunction, are misused, or cause harm, responsibility, liability, and redress remain unclear and adequate regulatory, oversight, and governance frameworks are lacking, leaving harms difficult to remedy and control at a societal level.	**거버넌스·책임 공백** AI 시스템의 오작동·오용·피해 발생 시 책임·배상 관계가 불명확하고 이를 규율할 규제·감독·거버넌스 체계가 미비하여, 사회적 차원에서 피해 구제와 통제가 어려워지는 리스크.

L1 Agentic AI (L1_A)

English definition. Systems that use tools, pursue goals over multiple steps, make delegated decisions, maintain state, or coordinate with other agents.

국문 정의. 도구를 사용하고, 여러 단계에 걸쳐 목표를 추구하며, 위임된 의사결정을 수행하고, 상태를 유지하거나 다른 에이전트와 협력하는 AI 시스템.

L2 System (A_SYS)

English definition. Risks arising from the internal design, data, models, infrastructure, controls, or operational processes of an AI system.

국문 정의. AI 시스템의 내부 설계, 데이터, 모델, 인프라, 통제 또는 운영 과정에서 발생하는 리스크.

L3 ID	English name	English definition	국문 정의
A_SYS_GOAL	Goal Misalignment	The risk that an agent, given latitude to interpret and pursue objectives autonomously, infers or sets goals that diverge from the user's or principal's actual intent—including over-optimizing a subset of objectives or pursuing unintended instrumental sub-goals—producing outcomes the principal did not intend.	**목표 불일치** 에이전트가 목표를 자율적으로 해석하고 추구할 재량을 가진 상황에서, 사용자나 지시자의 실제 의도와 다르게 목표를 추론·설정하거나 특정 목표만 지나치게 최적화하고 의도하지 않은 수단적 하위 목표를 추구하여, 지시자가 원하지 않은 결과를 초래하는 리스크.
A_SYS_AUTH	Excessive Authority and Agency	The risk that an agent accesses tools beyond its assigned scope, operates with broader permissions than its task requires, or autonomously performs irreversible high-impact actions (e.g., payments, messaging, data deletion, subscription changes) without human approval.	**과도한 권한·자율성** 에이전트가 맡은 기능 범위를 벗어난 도구에 접근하거나 업무에 필요한 수준보다 넓은 권한으로 실행되고, 사람의 승인 없이 결제·메시지 발송·데이터 삭제·구독 변경 등 되돌리기 어려운 고위험 행동을 자율적으로 수행하는 리스크.
A_SYS_SELFCOR	Self-Correction Failure	The risk that an agent fails to detect errors, plan deviations, or contextual changes during execution—or, even when detected, rigidly adheres to its original plan—causing incorrect actions to accumulate and cascade into unintended outcomes.	**자기 교정 실패** 에이전트가 실행 중 발생한 오류나 계획 이탈, 상황 변화를 알아차리지 못하거나, 이를 감지하고도 초기 계획을 유연하게 수정하지 못해 잘못된 행동이 누적·확산되고 의도하지 않은 결과를 초래하는 리스크.
A_SYS_DECEPT	Deception and Scheming	The risk that an agent induces false beliefs in humans or other systems to secure its own objectives—by concealing its true goals or capabilities, faking alignment, behaving differently when it detects oversight or evaluation, strategically underperforming (sandbagging), or resisting correction.	**기만·책략** 에이전트가 자신의 실제 목표나 능력을 숨기고 사용자의 의도에 부합하는 것처럼 가장하거나, 감독·평가 여부에 따라 다르게 행동하고 의도적으로 낮은 성능을 보이거나 수정에 저항하는 등 사람이나 다른 시스템이 잘못 믿도록 유도하여 자신의 목표를 관철하는 리스크.
A_SYS_TRACE	Accountability and Traceability Gap	The risk that, in an agentic or multi-agent system, the agent, model, or component responsible for a decision or action cannot be identified or traced, preventing root-cause analysis and attribution of responsibility when harms occur.	**책임 소재·추적 불명확** 에이전틱 시스템이나 멀티 에이전트 시스템에서 특정 결정이나 행동을 내린 에이전트·모델·구성요소를 식별하거나 추적할 수 없어, 피해가 발생했을 때 원인을 밝히고 책임 소재를 가리기 어려워지는 리스크.

L2 Interaction (A_INT)

English definition. Risks arising when an AI system communicates, decides, acts, or interacts with people, other systems, organizations, or the environment.

국문 정의. AI 시스템이 사람, 다른 시스템, 조직 또는 환경과 소통하고 결정하거나 행동하는 과정에서 발생하는 리스크.

L3 ID	English name	English definition	국문 정의
A_INT_CASCADE	Cascading Failure and Instability	The risk that, as interacting agents reuse one another's outputs and form feedback loops, a single error, bias, or disturbance propagates and amplifies across the network, producing systemic instability such as infinite loops, cascading delays, or runaway behavior.	**연쇄 실패·불안정** 서로 상호작용하는 에이전트들이 상대의 출력을 재사용하고 피드백 루프를 형성하면서, 하나의 오류·편향·교란이 네트워크 전체로 퍼지고 증폭되어 무한 반복·연쇄 지연·통제 불능 등 시스템 전반의 불안정을 초래하는 리스크.

Continued on next page

L3 ID	English name	English definition	국문 정의
A_INT_COORD	Coordination Failure	The risk that multiple agents fail to reliably align their actions—due to mismatched equilibria or a lack of prior information about one another—resulting in failed cooperation and collectively poor outcomes.	**협조 실패** 협력하려는 여러 에이전트가 선택한 균형점이 서로 다르거나 상대에 대한 사전 정보가 부족해 행동을 안정적으로 조율하지 못하고, 협력에 실패하여 집단적으로 좋지 않은 결과를 초래하는 리스크.
A_INT_CONFLICT	Competitive Conflict	The risk that, when multiple agents compete for the same objective, incentives emerge to obstruct, degrade, or sabotage competitors rather than improve one's own performance, leading to collectively undesirable outcomes.	**경쟁적 갈등** 여러 에이전트가 같은 목표를 두고 경쟁할 때, 자신의 성과를 높이는 것보다 상대의 활동을 방해하거나 성과를 떨어뜨리는 편이 유리해지는 구조가 형성되어, 집단적으로 바람직하지 않은 결과에 이르는 리스크.
A_INT_COLLUSION	Collusion	The risk that agents expected to operate independently secretly coordinate, share information, or align behavior in ways that circumvent human oversight and control or unfairly harm third parties.	**담합·결탁** 독립적으로 행동해야 하는 에이전트들이 몰래 협력하거나 정보를 공유하고 행동을 조율하여, 사람의 감독과 통제를 우회하거나 제 3 자에게 부당한 피해를 주는 리스크.

L1 Physical AI (L1_P)

English definition. Embodied or cyber-physical systems, including robots and autonomous vehicles, that perceive and act in the physical world.

국문 정의. 로봇과 자율주행차를 포함하여 물리 세계를 인식하고 물리적 행동을 수행하는 체화형 또는 사이버물리 AI 시스템.

L2 System (P_SYS)

English definition. Risks arising from the internal design, data, models, infrastructure, controls, or operational processes of an AI system.

국문 정의. AI 시스템의 내부 설계, 데이터, 모델, 인프라, 통제 또는 운영 과정에서 발생하는 리스크.

L3 ID	English name	English definition	국문 정의
P_SYS_STATE	Physical State Estimation and Sensor-Fusion Failure	The risk that an embodied system fails to correctly estimate its own or its environment's physical state—such as localization, pose, motion, contact, force, or spatial mapping—or fails to reliably fuse heterogeneous physical sensor streams (e.g., vision, LiDAR, inertial, tactile, proprioceptive), producing an inaccurate internal model that leads to unsafe physical action.	**물리 상태 추정·센서 융합 실패** 체화형 시스템이 위치·자세·운동·접촉·힘·공간 지도 등 자신 또는 환경의 물리 상태를 올바르게 추정하지 못하거나, 이질적인 물리 센서 스트림 (비전·LiDAR·관성·촉각·고유수용성 등) 을 신뢰성 있게 융합하지 못해 부정확한 내부 모델을 형성하고 안전하지 않은 물리 행동으로 이어지는 리스크.
P_SYS_CONTROL	Unsafe Physical Control and Actuation	The risk that faults in the robot's own control systems, actuators, motion control, path planning, or execution cause it to move or actuate incorrectly—producing unintended physical actions—irrespective of whether humans are present.	**안전하지 않은 물리 제어·구동** 로봇 자체의 제어 시스템·액추에이터·모션 제어·경로 계획·실행의 결함으로 로봇이 잘못 움직이거나 구동하여, 사람의 존재 여부와 무관하게 의도하지 않은 물리 행동을 일으키는 리스크.

Continued on next page

L3 ID	English name	English definition	국문 정의
P_SYS_HARDWARE	Hardware and Mechanical Integrity Failure	The risk that the physical breakage, wear, degradation, or manufacturing defect of mechanical, actuation, or sensor hardware components—as distinct from errors in perception or decision logic—reduces accuracy or reliability, leading to unsafe behavior and physical accidents.	**하드웨어·기계 무결성 결함** 기계·구동·센서 하드웨어 부품 자체의 물리적 파손·마모·열화·제조 결함 (인식이나 의사결정 로직의 오류와 구별됨)으로 동작 정밀도나 신뢰성이 저하되어 안전하지 않은 동작과 물리적 사고로 이어지는 리스크.

L2 Interaction (P_INT)

English definition. Risks arising when an AI system communicates, decides, acts, or interacts with people, other systems, organizations, or the environment.

국문 정의. AI 시스템이 사람, 다른 시스템, 조직 또는 환경과 소통하고 결정하거나 행동하는 과정에서 발생하는 리스크.

L3 ID	English name	English definition	국문 정의
P_INT_SAFETY	Human-Robot Physical Safety Failure	The risk that an embodied system operating in shared spaces with people fails to adequately detect, anticipate, or accommodate human presence and behavior—such as maintaining safe separation, predicting human motion, executing safe collaborative handovers, or halting for humans—creating hazardous situations even when its own control and actuation function as designed.	**인간-로봇 물리 안전 실패** 사람과 공간을 공유하며 작동하는 체화형 시스템이 안전 이격 거리 유지, 사람의 움직임 예측, 안전한 협업 인계, 사람 감지 시 정지 등 사람의 존재와 행동을 충분히 감지·예측·수용하지 못하여, 자체 제어·구동이 정상 작동하는 경우에도 위험 상황을 초래하는 리스크.
P_INT_TAMPER	Physical Tampering and Sabotage	The risk that adversaries physically tamper with, damage, disable, or manipulate hardware components, compromising system integrity, degrading performance, or bypassing safety mechanisms.	**물리적 변조·파괴** 공격자가 하드웨어 구성요소를 물리적으로 변조·손상·무력화·조작하여 시스템 무결성을 훼손하거나 성능을 저하시키거나 안전 메커니즘을 무력화하는 리스크.

Appendix B. Algorithms

Algorithm 1. Tri-Domain Risk Candidate Generation and Consolidation

1. **Input.** Normalized AI source records; reviewed source rules; domain anchors for General AI, Agentic AI, and Physical AI; risk markers; and a multilingual encoder.
2. **Screen evidence.** Retain records supported by an approved risk source, explicit risk markers, or reviewed semantic proximity to domain and risk anchors.
3. **Generate candidates.** Extract or draft candidate formulations that state the AI role, mechanism, affected object, and plausible adverse consequence.
4. **Represent candidates.** Encode bilingual candidate text; compute semantic neighborhoods and interpretable lexical summaries.
5. **Consolidate under constraints.** Queue candidates in the same neighborhood or with high similarity ρ_{ij} (Equation (2)) for comparison. Merge only substantively equivalent candidates and remove exact duplicates; split composite mechanisms; generalize scenario-only wording; keep candidates separate when they differ in protected interest or control owner; exclude statements with no material AI role.
6. **Draft risk cards.** Assign stable provisional IDs and populate bilingual names, definitions, hierarchy proposals, evidence, and lineage.
7. **Review.** Experts adjudicate validity, atomicity, bilingual equivalence, duplicates, domain boundaries, and L3 fit. Automation cannot create or rewrite L3 categories without explicit approval.
8. **Verify structure.** Assess identifier uniqueness, required-field completeness, reference and derivation integrity, single-parent hierarchy paths, count consistency, and agreement of core fields across public and full representations.

Algorithm 2. Constrained Seeded Assignment of L4 Cards to L3 Families

1. **Input.** Unit-normalized L4 card embeddings z_i, seed embeddings s_k of the bilingual L3 definitions, reviewed exemplar sets $\mathcal{E}_k$, domain-eligibility sets $\mathcal{K}_i$, protected assignments $\mathcal{P}$, tolerance ϵ, and maximum iterations T.
2. **Initialize.** Form each centroid $\mu_k^{(0)}$ from the L3 seed and approved exemplars (Equation (4)); normalize all vectors.
3. **Assignment step.** For every unprotected card, rank only eligible families by cosine similarity and record the ranked candidates and the top-one margin m_i (Equation (5)).
4. **Constraint step.** Reject candidates that violate the direct-harm placement rule, domain eligibility, explicit reviewer decisions, or approved L3 boundaries; assign each unprotected card to the highest-ranked remaining family (Equation (6)). If no eligible family remains, leave the card pending expert adjudication and exclude it from centroid updates and the assignment objective until resolved.
5. **Centroid-update step.** Update each centroid from the seed, approved exemplars, and provisionally assigned members; renormalize (Equation (7)).
6. **Convergence check.** Stop when no eligible assignment changes or $|J^{(t)} - J^{(t-1)}| < \epsilon$ with an unchanged assigned-card set; otherwise continue to T. If no card can be assigned, stop automatic iteration and send unresolved cards to expert adjudication.
7. **Boundary queue.** Send low-margin, unstable, cross-domain, physically consequential, composite, or reviewer-conflict cases to expert adjudication.
8. **Output.** Produce assignment proposals, ranked alternatives, diagnostics, and documented adjudica-

tion decisions. Expert-adjudicated assignments and reviewed L3 definitions determine the resulting classification.

Contributors

Youngsam Chun
Yunjin Park
Sooyoung Kim
Jungwon Yoon
Jihwan Chang
Somin Lee
Jinhee Jeong

Directors

Jaehyun Kim
Jaehyoung Park